

DETECTION / RESPONSE / ACCESS / RISK

# Cybersecurity English

Report the evidence. Explain the exposure.

**Phil Stilwell**

© 2026 Phil Stilwell. All rights reserved.

No part of this publication may be reproduced, stored in a retrieval system, or transmitted in any form or by any means without prior written permission from the author, except as permitted by law.



**Eight lessons. Eleven extended conversations.**

## INSIDE THE BOOK

192 vocabulary entries / 128 reusable phrases  
220 extended-dialogue turns / 11 transfer exchanges  
Word banks and explained answer keys

Upper-intermediate to advanced (B2-C1). For security analysts, engineers, risk specialists, and cross-functional response teams.

2026 edition

# Eight scenarios. Eight skills.

Eight security conversations connect technical observations with defensible conclusions, authorized action, and clear business decisions.

## 01 Security Triage and Alert Investigation

4

A successful login is not verified authorization | Give a concise alert handoff that separates logged events, plausible explanations, and unresolved authorization.

## 02 Incident Response and Containment

13

Isolation is complete; the investigation is not | Coordinate a response update with action status, operational impact, evidence preservation, and a defined next report.

## 03 Vulnerability Management

22

The same score, a different repair priority | Explain a risk-based remediation order without treating severity scores as complete business-risk assessments.

## 04 Identity, Access, and Least Privilege

31

Support needs logs, not a shared administrator | Negotiate a specific access arrangement using identity, task, permission, duration, approval, and accountability.

## 05 Threat Modeling and Secure Design

40

A sign-in check does not decide document access | Trace a data flow, identify a trust boundary, and turn a specific abuse case into a testable design requirement.

## 06 Governance, Risk, and Compliance

49

A written policy does not close the control finding | Describe audit evidence, distinguish missing proof from proven failure, and state the actual closure conditions.

## 07 Security Awareness and Phishing

58

Report the click, without guessing the consequence | Elicit a precise suspicious-message report, encourage prompt disclosure, and avoid requests for secrets or unsupported reassurance.

## 08 Executive Risk Briefings

67

A recovery shortfall needs a bounded decision | Connect a measured security gap to a business consequence and a specific investment request without claiming guaranteed risk elimination.

Communication field notes

3

Three more workplace conversations

76

Answers and explanations

85

Fast-access phrase pages

104

Vocabulary index

106

Sources and publication notes

114

# Precision matters before certainty arrives.

Security teams often speak while the evidence is incomplete. An unusual login is not automatically an intrusion; a containment action is not proof of recovery. These conversations practice the language needed to act promptly while keeping observations, hypotheses, authority, and business consequences distinct.

## Name the evidence first

Give the source, event time, and observed behavior before the interpretation. Preserve uncertainty without hiding the need to act.

"The log records a successful sign-in; authorization is not yet verified."

## Bound a negative finding

A search result applies to the sources and period actually checked. Missing records cannot prove that nothing happened.

"We found no matching event in the available application logs."

## Separate action from outcome

Proposed, approved, completed, and verified describe different states. Identify who can authorize a disruptive response.

"Isolation is complete; eradication and recovery are not yet confirmed."

## Translate risk into a decision

Connect a specific exposure to a plausible business consequence, then state the requested action and what remains uncertain.

"The proposal addresses delayed payroll recovery, not every cyber risk."

### PROFESSIONAL BOUNDARIES

Original fictional English practice, not a security certification, incident-response playbook, legal opinion, or authorization to test systems. Follow the responsible team, approved procedures, evidence-handling rules, and applicable requirements. All organizations, incidents, figures, priorities, and control criteria in the cases are invented.

# A successful login is not verified authorization

## A Read the situation

**Give a concise alert handoff that separates logged events, plausible explanations, and unresolved authorization.**

Analyst Anika reviews alert S14 with shift lead Luis. The identity log records a successful privileged-account sign-in at 02:14 UTC from an unfamiliar address. A maintenance ticket covers 02:00-03:00 UTC, but its host and account have not been matched to the event. The account owner has not replied. Application logs are missing for 02:10-02:20 UTC. No malicious action is confirmed. The local process requires escalation to Luis now while correlation continues.

PEOPLE / Anika: Security analyst | Luis: Shift lead

### ASK WITHOUT ACCUSING

A direct question about who authorized an action is a request for evidence, not necessarily an accusation. Use event details and neutral verbs. Neither familiarity with a colleague nor an urgent alert label settles whether a particular action was permitted.

## Briefing checks

Circle one answer in each item. Use the briefing.

1. What does the identity log establish?

**A** A verified match to the maintenance ticket

**B** Complete application visibility

**C** A successful privileged-account sign-in at 02:14 UTC

**D** A confirmed hostile actor

2. What is missing from 02:10-02:20 UTC?

**A** Application logs

**B** Every identity record

**C** The maintenance ticket

**D** The alert identifier

3. What does the local process require now?

**A** Calling the account owner malicious

**B** Escalation to Luis while correlation continues

**C** Closure because maintenance was scheduled

**D** Waiting for certainty before informing anyone

[Answers and explanations: page 85.](#)

# The vocabulary that does the work

## B Find the words / 1 of 2

Read the definitions and say the common word combinations aloud.

### alert

A notification that a detection condition was met.

**IN USE** triage an alert

### event

An observable occurrence recorded by a system.

**IN USE** correlate events

### incident

An occurrence assessed as compromising or threatening security.

**IN USE** classify an incident

### triage

Initial assessment to decide priority and next handling.

**IN USE** perform security triage

### privileged account

An identity with elevated system permissions.

**IN USE** review privileged-account activity

### successful sign-in

A recorded completion of an authentication process.

**IN USE** verify a successful sign-in

### authentication

Checking evidence that an identity claim is valid.

**IN USE** examine authentication records

### authorization

Permission for a particular action or resource.

**IN USE** confirm authorization

### source address

A network address associated with an observed connection.

**IN USE** investigate a source address

### timestamp

A recorded time associated with an event.

**IN USE** preserve the timestamp

### UTC

Coordinated Universal Time, a shared time reference.

**IN USE** report times in UTC

### maintenance window

A defined period for planned maintenance work.

**IN USE** confirm the maintenance window

### Precision check

A successful authentication does not establish that the account holder intended or authorized the action. A matching time window supports a possible maintenance explanation, not a confirmed match to this event.

# The vocabulary that does the work

## B Find the words / 2 of 2

Read the definitions and say the common word combinations aloud.

### correlation

Relating records to assess whether events are connected.

**IN USE correlate identity and host logs**

### log source

A system or service producing event records.

**IN USE identify the log source**

### telemetry

System observations collected for monitoring or analysis.

**IN USE review available telemetry**

### visibility gap

A period or area lacking needed observation data.

**IN USE disclose a visibility gap**

### baseline

A reference pattern used to evaluate current behavior.

**IN USE compare activity with the baseline**

### anomaly

A departure from an expected pattern.

**IN USE investigate an anomaly**

### false positive

A detection that incorrectly indicates the target condition.

**IN USE validate a false positive**

### benign activity

Activity assessed as not harmful in its context.

**IN USE confirm benign activity**

### indicator

An observable sign that can support an investigation.

**IN USE assess an indicator**

### hypothesis

A proposed explanation awaiting evaluation.

**IN USE test the maintenance hypothesis**

### confidence level

A qualified assessment of evidential strength.

**IN USE state the confidence level**

### case record

A documented account of observations and handling.

**IN USE update the case record**

### Precision check

No malicious action confirmed is not the same as no malicious action occurred. The missing application logs restrict what the team can exclude; keep that limitation in the handoff.

# Phrases you can actually use

## **C** Notice the language / 1 of 2

### LEAD WITH THE EVENT

"The identity log records a successful sign-in at 02:14 UTC."

### SEPARATE THE CONCLUSION

"Authorization is not yet verified."

### LIMIT THE MATCH

"We have not matched the host and account."

### AVOID AN ACCUSATION

"Who can confirm the authorized operator?"

### IDENTIFY THE PRIVILEGE

"The event involves a privileged account."

### NAME THE PLAUSIBLE EXPLANATION

"The timing overlaps planned maintenance."

### IDENTIFY MISSING EVIDENCE

"Application logs are missing for ten minutes."

### PRESERVE URGENCY

"I am escalating while correlation continues."

---

### Successful

Describes the sign-in result, not permission or intent.

### Unfamiliar

A comparison with known patterns, not proof of hostility.

### Confirmed

Use only when the stated conclusion has supporting evidence.

# Phrases you can actually use

## **C** Notice the language / 2 of 2

### STATE UNCERTAINTY

"No malicious action is confirmed at this point."

### USE NEUTRAL WORDING

"The address is unfamiliar, not yet classified as hostile."

### KEEP TIME CONSISTENT

"Both timestamps are reported in UTC."

### NAME THE NEXT CHECK

"We will compare the ticket, account, and host."

### BOUND THE SEARCH

"That conclusion applies only to the sources checked."

### ASK FOR A RECORD

"Please provide the relevant maintenance approval."

### REJECT PREMATURE CLOSURE

"The maintenance window alone does not close the alert."

### CLOSE THE HANDOFF

"S14 remains under investigation with a documented visibility gap."

---

### No evidence found

Name the sources, period, and missing observations.

### May be

Introduces a possibility without treating it as established.

### Escalate

Means involve the required authority, not necessarily declare a breach.

# Choose the precise message

## **D** Check your understanding

Circle one best answer for each item. Use the stated purpose and case facts, not the option that merely sounds most polite.

### 1. Which handoff best fits S14?

- A** Successful privileged sign-in; authorized maintenance; application-log gap; awaiting closure.
- B** Successful privileged sign-in; authorization unverified; complete application visibility; escalated.
- C** Successful privileged sign-in; authorization unverified; application-log gap; escalation deferred until the owner replies.
- D** Successful privileged sign-in; authorization unverified; application-log gap; escalated for investigation.

### 2. Which record would help test the maintenance explanation?

- A** A ticket matching this host, account, and authorized task
- B** A ticket from a different server at any time
- C** The owner's seniority alone
- D** The alert's red display color

### 3. Why is the log gap relevant?

- A** It proves the actor deleted all records.
- B** It changes UTC into local time.
- C** It makes the successful sign-in disappear.
- D** It limits what the team can exclude about application activity.

### 4. Which wording avoids premature blame?

- A** The account was used; the operator is not yet verified.
- B** The account owner attacked the system.
- C** The owner must have approved the activity.
- D** Every unfamiliar address is malicious.

Answers and explanations: [page 85](#).

# A successful login is not verified authorization

## E Conversations / turns 1-10

Complete the numbered gaps. Use each bank entry once, without changing its form. Cover the answers at the end until you finish.

### WORD + PHRASE BANK

event / authorization / case record / authentication / hypothesis / correlation / visibility gap / anomaly / triage / confidence level

- 01 **Anika:** S14 triggered on a privileged sign-in at two fourteen UTC. The address is unfamiliar. I have the identity record, but not an explanation yet.
- 02 **Luis:** Start with the <sup>1</sup> \_\_\_\_\_, then tell me what remains unknown. A successful sign-in matters, but I do not want the handoff to imply confirmed hostile activity.
- 03 **Anika:** There is a maintenance ticket from two to three UTC. The timing overlaps, although I have not matched its host or account to this record.
- 04 **Luis:** Then maintenance is a <sup>2</sup> \_\_\_\_\_, not a closure reason. We need the actual task, operator, and asset match before describing this particular sign-in as approved work.
- 05 **Anika:** I nearly waited for the owner to reply before calling you. Should I escalate now and keep the maintenance explanation provisional?
- 06 **Luis:** Keep <sup>3</sup> \_\_\_\_\_ moving. Our process requires escalation now, and your uncertainty belongs in the update. We can investigate without accusing the owner or announcing a confirmed intrusion.
- 07 **Anika:** I also found missing application logs between two ten and two twenty UTC. That interval includes the identity event we are discussing.
- 08 **Luis:** Record the <sup>4</sup> \_\_\_\_\_ explicitly. We cannot use an incomplete application search to say that nothing happened after the sign-in, even if the records we have look ordinary.
- 09 **Anika:** The dashboard says new address. Is that enough to label the source hostile, or should I just report that it is unfamiliar?
- 10 **Luis:** Call it an <sup>5</sup> \_\_\_\_\_. It deserves investigation, but novelty does not establish who controlled the connection. The maintenance explanation still needs testing, just as the hostile explanation does.

# The conversation, continued

## E Conversations / turns 11-20

Continue with the word bank on page 10.

- 11 **Anika:** Understood. I will say that the identity log records success, the source is unfamiliar, and the account holder has not confirmed the activity.
- 12 **Luis:** Separate <sup>6</sup> \_\_\_\_\_ from permission. The recorded login result does not establish that the operator was entitled to perform the particular task at that time.
- 13 **Anika:** I will request the relevant approval through our internal channel. The ticket number alone is not enough without checking which account and host it covers.
- 14 **Luis:** Exactly. We need <sup>7</sup> \_\_\_\_\_ evidence tied to the action. Keep the original event details and identify any later corrections instead of silently rewriting the first report.
- 15 **Anika:** For the next shift, I will list the identity record, maintenance ticket, unanswered owner request, and missing application interval together in S14.
- 16 **Luis:** Put that in the <sup>8</sup> \_\_\_\_\_. The next analyst should see both the current evidence and the reason this alert remains open, without reconstructing the conversation.
- 17 **Anika:** I will compare the ticket against the host and account, then update the working explanation when that evidence arrives. No malicious action is confirmed.
- 18 **Luis:** Describe your <sup>9</sup> \_\_\_\_\_ carefully. We have a real observation and unresolved context. Repeating the same possibility does not turn it into stronger evidence.
- 19 **Anika:** My handoff will keep the event time in UTC and state that the missing application records limit our ability to exclude later activity.
- 20 **Luis:** Good. Continue the <sup>10</sup> \_\_\_\_\_ and keep me involved under the escalation process. The status is under investigation, with authorization unverified and the visibility limitation clearly recorded.

### ANSWERS / EXPLANATIONS: PAGE 86

1. event | 2. hypothesis | 3. triage | 4. visibility gap | 5. anomaly | 6. authentication | 7. authorization | 8. case record | 9. confidence level | 10. correlation

# Overlap is still not a match

## F Say it

Alert T8 records a sign-in at 05:20 UTC. Maintenance was scheduled from 05:00-06:00, but the account match is unverified. Application logs are unavailable. The shift lead has received the escalation.

Complete the four gaps. Use each bank entry once.

### WORD + PHRASE BANK

received / unverified / unavailable / UTC

Analyst: "The event time is 05:20 <sup>1</sup> \_\_\_\_\_."

Lead: "The account match remains <sup>2</sup> \_\_\_\_\_."

Analyst: "Application logs are <sup>3</sup> \_\_\_\_\_."

Lead: "The escalation has been <sup>4</sup> \_\_\_\_\_."

### ANSWERS / EXPLANATIONS: PAGE 86

1. UTC | 2. unverified | 3. unavailable | 4. received

## Rehearse with a fixed script

1. Read turns 1-10. Stress observed facts separately from the maintenance hypothesis.
2. Switch roles for turns 11-20. Keep authentication distinct from authorization.
3. Check the transfer. Read the UTC time and the two missing-evidence statements clearly.

### WORKING ALONE

Read both roles, pausing for two seconds when the speaker changes. Repeat with the bank covered, then check any missed expressions.

# Isolation is complete; the investigation is not

## A Read the situation

**Coordinate a response update with action status, operational impact, evidence preservation, and a defined next report.**

Incident coordinator Mara briefs service owner Joel about suspected unauthorized activity on billing host B7, first reported at 09:10 UTC. Under the approved playbook, Mara authorized network isolation at 09:18; completion was verified at 09:22. Billing jobs are paused. Investigators are preserving available evidence; cause, data access, and wider scope remain unconfirmed. Restoration requires the response lead and service owner under the local process. The next update is due at 09:45, not a promised restoration time.

PEOPLE / Mara: Incident coordinator | Joel: Billing service owner

### BE DECISIVE ABOUT THE ACTION, EXACT ABOUT THE RESULT

During a response, colleagues need short updates that they can repeat accurately. Separate the completed action from what it has not established. A calm statement of uncertainty is more useful than either dramatic speculation or premature reassurance.

## Briefing checks

Circle one answer in each item. Use the briefing.

1. When was isolation completion verified?

- A 09:45 UTC
- C 09:10 UTC

- B 09:22 UTC
- D 09:18 UTC

2. What is the confirmed operational impact?

- A All customer records were stolen.
- C Billing has been fully restored.

- B Every service is unavailable.
- D Billing jobs are paused.

3. What does 09:45 represent?

- A The proven intrusion start
- C The next update time

- B Automatic closure
- D A guaranteed restoration time

Answers and explanations: page 87.

# The vocabulary that does the work

## B Find the words / 1 of 2

Read the definitions and say the common word combinations aloud.

### incident response

Coordinated handling of a suspected or confirmed security incident.

**IN USE coordinate incident response**

### containment

Action intended to limit incident spread or impact.

**IN USE verify containment actions**

### network isolation

Restricting a system's network connections.

**IN USE confirm network isolation**

### eradication

Removal of incident causes or persistence as applicable.

**IN USE verify eradication**

### recovery

Restoring affected capabilities under the required checks.

**IN USE authorize recovery**

### response lead

The person directing the assigned response process.

**IN USE brief the response lead**

### service owner

The role responsible for a business or technical service.

**IN USE involve the service owner**

### playbook

Agreed guidance for handling a defined situation.

**IN USE follow the approved playbook**

### action log

A time-ordered record of response actions.

**IN USE maintain the action log**

### evidence preservation

Protecting relevant records and artifacts from loss or alteration.

**IN USE coordinate evidence preservation**

### chain of custody

Documentation of evidence handling and transfers.

**IN USE maintain chain of custody**

### volatile data

Information that may be lost when system state changes.

**IN USE preserve volatile data appropriately**

### Precision check

09:18 is the authorization time; 09:22 is verified completion. Saying isolated at 09:18 would merge two different events. Record both so later reviewers can reconstruct what actually happened.

# The vocabulary that does the work

## B Find the words / 2 of 2

Read the definitions and say the common word combinations aloud.

### affected host

A system within the known impact or investigation scope.

**IN USE identify the affected host**

### incident scope

The systems, accounts, and effects covered by an incident assessment.

**IN USE establish incident scope**

### lateral movement

Movement from an initial foothold to other systems.

**IN USE investigate possible lateral movement**

### persistence

A means of retaining access across changes or restarts.

**IN USE assess persistence**

### exfiltration

Unauthorized transfer of data outside the relevant boundary.

**IN USE investigate possible exfiltration**

### restoration criterion

A condition required before returning a service.

**IN USE confirm restoration criteria**

### business impact

A consequence for organizational operations or objectives.

**IN USE report business impact**

### status update

A time-specific summary of the current position.

**IN USE issue a status update**

### decision authority

The role permitted to approve a particular action.

**IN USE confirm decision authority**

### handover

Transfer of responsibility and relevant information.

**IN USE complete the response handover**

### post-incident review

A review of events and improvements after handling an incident.

**IN USE schedule a post-incident review**

### root cause

An underlying reason supported by investigation evidence.

**IN USE establish the root cause**

### Precision check

Isolation may limit exposure but does not establish the full incident scope, removal of persistence, or readiness to restore. Here, the next update is fixed while the recovery time remains unknown.

# Phrases you can actually use

## C Notice the language / 1 of 2

### STATE THE CURRENT IMPACT

"Billing jobs are paused on B7."

### SEPARATE APPROVAL FROM ACTION

"Isolation was authorized at 09:18."

### NAME THE UNKNOWN

"The cause and wider scope remain unconfirmed."

### PROTECT THE RECORD

"Evidence preservation is in progress."

### GIVE THE FIRST REPORT

"The activity was first reported at 09:10 UTC."

### CONFIRM EXECUTION

"Completion was verified at 09:22."

### AVOID A FALSE ALL-CLEAR

"Containment does not establish recovery readiness."

### ASSIGN THE DECISION

"Restoration requires the response lead and service owner."

---

### Reported at

Not necessarily the time the underlying activity began.

### Authorized

Permission was given; execution still needs verification.

### Contained

Define what action and scope support this description.

# Phrases you can actually use

## C Notice the language / 2 of 2

### BOUND THE STATEMENT

"We have not confirmed unauthorized data access."

### CORRECT THE DATE MEANING

"That is an update time, not a restoration estimate."

### KEEP ACTIONS TRACEABLE

"Please record the authorization and completion separately."

### PREPARE THE HANDOVER

"Include completed actions, open questions, and owners."

### COMMIT TO COMMUNICATION

"The next update will be at 09:45."

### ACKNOWLEDGE DISRUPTION

"I recognize the impact on billing operations."

### AVOID AN IMPROVISED CHANGE

"Use the response process before changing system state."

### CLOSE WITH THE CURRENT STATUS

"B7 is isolated; investigation and recovery assessment continue."

---

## Compromised

Do not replace suspected activity with a stronger conclusion.

## Restore

Requires the relevant technical and operational checks.

## Next update

A commitment to communicate, not a promise of resolution.

# Choose the precise message

## **D** Check your understanding

Circle one best answer for each item. Use the stated purpose and case facts, not the option that merely sounds most polite.

### 1. Which timeline is accurate?

- A** Isolation complete 09:18 because authorization was given.
- B** Incident closed 09:22 because a host was isolated.
- C** Report 09:10; isolation authorized 09:18; completion verified 09:22.
- D** Intrusion proven to begin 09:10; recovery complete 09:18.

### 2. Which reply addresses pressure to restore now?

- A** Treat the update deadline as automatic permission to reconnect.
- B** Say all systems are clean because one host is isolated.
- C** Billing is paused; restoration still requires the specified response and service-owner process.
- D** Restore immediately because isolation proves the cause is removed.

### 3. Which statement about data access is justified?

- A** Unauthorized data access has not been confirmed.
- B** No data was accessed under any circumstances.
- C** All billing data was exfiltrated.
- D** Isolation proves that no earlier transfer occurred.

### 4. What belongs in the handover?

- A** An undocumented restoration promise
- B** Actions, timestamps, impact, open questions, and responsible roles
- C** Only a reassuring headline
- D** A root cause selected to end uncertainty

Answers and explanations: [page 87](#).

# Isolation is complete; the investigation is not

## E Conversations / turns 1-10

Complete the numbered gaps. Use each bank entry once, without changing its form. Cover the answers at the end until you finish.

### WORD + PHRASE BANK

containment / incident scope / status update / Recovery / business impact / action log /  
Eradication / handover / decision authority / Evidence preservation

- 01 **Joel:** Billing is paused, and the team wants a restoration time. We know B7 is isolated. Can I tell them the incident is now over?
- 02 **Mara:** No. The <sup>1</sup> \_\_\_\_\_ action is complete, but cause, data access, and wider scope remain unconfirmed. We should be precise about what that completed action means.
- 03 **Joel:** Give me the timeline so I can explain the interruption. I have nine ten in the report and nine eighteen in the response channel.
- 04 **Mara:** The <sup>2</sup> \_\_\_\_\_ should show first report at nine ten, isolation authorization at nine eighteen, and verified completion at nine twenty-two, all UTC.
- 05 **Joel:** I put nine eighteen as the isolation time in my update. That was only permission to act. I will change it to nine twenty-two.
- 06 **Mara:** Please also keep the <sup>3</sup> \_\_\_\_\_ concrete: billing jobs are paused. We have not established that every related service is affected or that customer data left the environment.
- 07 **Joel:** Would restarting B7 help us resume sooner? Someone suggested it in the operations channel, but I do not know what investigators still need.
- 08 **Mara:** Route that request through the response team. <sup>4</sup> \_\_\_\_\_ is in progress, and an improvised state change could affect the investigation. We must coordinate recovery and evidence needs.
- 09 **Joel:** I will stop treating restart as a routine operations decision here. Who needs to agree before this service can return under our process?
- 10 **Mara:** The <sup>5</sup> \_\_\_\_\_ includes the response lead and you as service owner. Technical checks and operational consequences need to be assessed together before restoration.

# The conversation, continued

## E Conversations / turns 11-20

Continue with the word bank on page 19.

- 11 **Joel:** I can explain the business impact and available operational options. I cannot certify from isolation alone that the underlying problem has been removed.
- 12 **Mara:** Correct. <sup>6</sup> \_\_\_\_\_ has not been confirmed. We also cannot infer the absence of earlier unauthorized data access from the fact that connections are restricted now.
- 13 **Joel:** The team has also asked whether other hosts are involved. I only have the report about B7, so I have not named additional systems.
- 14 **Mara:** Keep the <sup>7</sup> \_\_\_\_\_ open in the update. One known host does not prove that there are no others, but uncertainty is not evidence that all systems are affected.
- 15 **Joel:** What can I promise for nine forty-five: an update, or a working service? People will read the time as a restoration deadline unless I spell it out.
- 16 **Mara:** Yes, as a <sup>8</sup> \_\_\_\_\_. We will report what changed, what remains unresolved, and the next actions then. That time is not a restoration estimate.
- 17 **Joel:** I will say that plainly. I also need the next shift to understand what was authorized and which checks are still open when they arrive.
- 18 **Mara:** Use the <sup>9</sup> \_\_\_\_\_ record, including timestamps, owners, and outstanding decisions. They should not have to infer permission from a short chat message or an optimistic headline.
- 19 **Joel:** My message will say B7 is isolated, billing jobs remain paused, and investigation continues. I will reserve any all-clear for the authorized process.
- 20 **Mara:** That is accurate. <sup>10</sup> \_\_\_\_\_ remains subject to the required checks and joint decision. We will give the next factual update at nine forty-five even if uncertainty remains.

### ANSWERS / EXPLANATIONS: PAGE 88

1. containment | 2. action log | 3. business impact | 4. Evidence preservation | 5. decision authority | 6. Eradication | 7. incident scope | 8. status update | 9. handover | 10. Recovery

# A report time is not a recovery deadline

## F Say it

Host C4 was first reported at 11:00 UTC. Isolation was authorized at 11:05 and verified complete at 11:09. The next update is 11:30. Recovery has not been authorized.

Complete the four gaps. Use each bank entry once.

### WORD + PHRASE BANK

11:30 / unauthorized / 11:09 / 11:05

Coordinator: "Isolation was authorized at <sup>1</sup> \_\_\_\_\_ UTC."

Owner: "Completion was verified at <sup>2</sup> \_\_\_\_\_ UTC."

Coordinator: "Our next update is at <sup>3</sup> \_\_\_\_\_ UTC."

Owner: "Recovery remains <sup>4</sup> \_\_\_\_\_."

### ANSWERS / EXPLANATIONS: PAGE 88

1. 11:05 | 2. 11:09 | 3. 11:30 | 4. unauthorized

## Rehearse with a fixed script

1. Read turns 1-10. Give report, authorization, and completion times as separate events.
2. Switch roles for turns 11-20. Stress that the next update is not a recovery promise.
3. Check the transfer. Read the three times without swapping authorization and execution.

### WORKING ALONE

Read both roles, pausing for two seconds when the speaker changes. Repeat with the bank covered, then check any missed expressions.

# The same score, a different repair priority

## A Read the situation

**Explain a risk-based remediation order without treating severity scores as complete business-risk assessments.**

Vulnerability analyst Chen and infrastructure owner Petra review two fictional findings, each with a base severity score of 8.8. A affects an internet-facing production gateway; a validated threat bulletin reports exploitation of that flaw elsewhere. B affects an isolated test server containing synthetic data, with no route from the internet. No local exploitation is confirmed. Their agreed rule prioritizes demonstrated exploitation and external exposure when scores tie. A patch is available for each; testing, change approval, and verification remain required.

PEOPLE / Chen: Vulnerability analyst | Petra: Infrastructure owner

### EXPLAIN THE RANKING, NOT JUST THE NUMBER

Operations teams need a reason to interrupt planned work. Connect the weakness to the affected asset, exposure, and exploitation evidence. A defensible priority is more persuasive than repeating a severity label while ignoring operational change controls.

## Briefing checks

Circle one answer in each item. Use the briefing.

1. Which finding comes first under the stated tie-break rule?

- A A, the exposed production gateway flaw
- B B, because test systems always come first
- C Both must have identical handling because scores match
- D Neither, because local exploitation is unconfirmed

2. What does the threat bulletin establish?

- A This organization is definitely compromised.
- B The patch has passed local tests.
- C B is reachable from the internet.
- D The flaw has been exploited elsewhere.

3. What remains required after selecting A first?

- A Closing both findings immediately
- B Testing, change approval, and verification
- C Only updating the priority label
- D Assuming the available patch is already installed

Answers and explanations: [page 89](#).

# The vocabulary that does the work

## B Find the words / 1 of 2

Read the definitions and say the common word combinations aloud.

### vulnerability

A weakness that can be exploited to harm security.

**IN USE** assess a vulnerability

### CVE

Common Vulnerabilities and Exposures, an identification system.

**IN USE** reference a CVE identifier

### CVSS

Common Vulnerability Scoring System, a severity framework.

**IN USE** interpret a CVSS score

### base score

A severity score based on intrinsic vulnerability characteristics.

**IN USE** compare base scores

### exploit

A means of taking advantage of a vulnerability.

**IN USE** assess exploit availability

### exploitation in the wild

Observed real-world use of a vulnerability.

**IN USE** confirm exploitation in the wild

### KEV catalog

CISA's list of vulnerabilities known to have been exploited.

**IN USE** check the KEV catalog

### internet-facing

Reachable through an internet-exposed service or interface.

**IN USE** inventory internet-facing assets

### asset criticality

The importance of an asset to organizational objectives.

**IN USE** assess asset criticality

### attack surface

The exposed points through which a system can be targeted.

**IN USE** reduce the attack surface

### reachability

Whether a relevant path to an asset or service exists.

**IN USE** verify reachability

### affected version

A software version within a vulnerability's stated scope.

**IN USE** confirm the affected version

### Precision check

A base severity score describes vulnerability characteristics, not the complete risk to a particular organization. Exposure, affected assets, observed exploitation, and local controls can justify different priorities for equal scores.

# The vocabulary that does the work

## B Find the words / 2 of 2

Read the definitions and say the common word combinations aloud.

### patch

A software update intended to correct a defect.

**IN USE validate a patch**

### remediation

Work to resolve an identified weakness or problem.

**IN USE prioritize remediation**

### mitigation

A measure intended to reduce exposure or impact.

**IN USE verify a mitigation**

### compensating control

An alternative safeguard addressing a defined control need.

**IN USE evaluate a compensating control**

### remediation window

An agreed period for completing corrective work.

**IN USE agree a remediation window**

### change approval

Permission to carry out a defined system change.

**IN USE obtain change approval**

### regression test

A check that a change has not broken existing behavior.

**IN USE run regression tests**

### rescan

A follow-up scan to reassess a finding.

**IN USE perform a rescan**

### false finding

A reported weakness not supported after validation.

**IN USE investigate a false finding**

### exception expiry

The date or condition ending an approved exception.

**IN USE track exception expiry**

### risk acceptance

An authorized decision to retain a specified risk.

**IN USE document risk acceptance**

### closure evidence

Records showing that the required completion conditions were met.

**IN USE attach closure evidence**

### Precision check

A patch being available is not evidence that it has been deployed successfully. Separate selection, testing, authorization, installation, and verification. A missing local incident does not erase the supplied reasons for prompt remediation.

# Phrases you can actually use

## C Notice the language / 1 of 2

03

### ACKNOWLEDGE THE TIE

"Both findings have a base score of 8.8."

### NAME THE EXPOSURE

"That service is internet-facing."

### PRESERVE LOCAL UNCERTAINTY

"We have not confirmed local exploitation."

### KEEP B VISIBLE

"B remains in the remediation queue."

### ADD THE ASSET CONTEXT

"A affects the production gateway."

### QUALIFY THE THREAT EVIDENCE

"The bulletin confirms exploitation elsewhere."

### APPLY THE AGREED RULE

"Our tie-break rule prioritizes A."

### DISTINGUISH AVAILABILITY

"The patch is available, not yet deployed."

---

### Severe

A characteristic assessment, not a complete priority decision.

### Exploited elsewhere

Supports urgency without establishing local compromise.

### Isolated

Verify the actual network and access boundaries.

# Phrases you can actually use

## C Notice the language / 2 of 2

03

### KEEP CHANGE CONTROLS

"Priority does not replace testing or approval."

### SPECIFY VERIFICATION

"Attach evidence that the affected condition is resolved."

### BOUND A MITIGATION

"State which exposure the temporary control reduces."

### CLARIFY THE DECISION

"We are selecting the work order, not declaring an incident."

### ASK ABOUT SERVICE IMPACT

"What interruption does the approved change require?"

### AVOID AN UNSUPPORTED CLOSURE

"An installation message alone does not close the finding."

### NAME THE EXCEPTION OWNER

"Any delay needs the required owner and expiry."

### CLOSE WITH A HANDOFF

"Record A first, B still open, and the remaining change steps."

---

### Available

Does not mean tested, approved, or installed.

### Resolved

Needs evidence against the finding's closure criteria.

### Accept

A risk decision requiring the designated authority.

# Choose the precise message

## **D** Check your understanding

Circle one best answer for each item. Use the stated purpose and case facts, not the option that merely sounds most polite.

### 1. Which explanation is strongest for A first?

- A** Equal scores; A adds external exposure and validated exploitation evidence under the agreed rule.
- B** A has a higher supplied score.
- C** B has no possible risk under any circumstances.
- D** A is already proven to be compromised locally.

### 2. Which statement about B is accurate?

- A** It is permanently exempt because it uses synthetic data.
- B** Its score must be changed to zero.
- C** It is internet-facing because A is.
- D** It is lower in this ordering but still requires handling.

### 3. What distinguishes a patch from a mitigation?

- A** A patch changes software; another control may reduce exposure without correcting that software.
- B** Every mitigation installs a patch.
- C** A patch is only a risk-acceptance signature.
- D** A mitigation proves all vulnerabilities are absent.

### 4. Which closure message is supported before any deployment?

- A** The threat bulletin certifies local recovery.
- B** A is prioritized; deployment and verification are still pending.
- C** A is resolved because a patch exists.
- D** Both findings are closed because a plan exists.

Answers and explanations: [page 89](#).

# The same score, a different repair priority

## E Conversations / turns 1-10

Complete the numbered gaps. Use each bank entry once, without changing its form. Cover the answers at the end until you finish.

### WORD + PHRASE BANK

mitigation / risk acceptance / change approval / base score / internet-facing / asset criticality / remediation / exploitation in the wild / closure evidence / regression test

- 01 **Petra:** Both findings are eight point eight. The operations queue usually sorts by score, so I need a clear reason to move the gateway ahead.
- 02 **Chen:** The <sup>1</sup> \_\_\_\_\_ is the same, but our tie-break rule uses exposure and demonstrated exploitation. A has both of those additional facts in the supplied assessment.
- 03 **Petra:** Let us separate those facts. A is the production gateway reachable externally. B is an isolated test server holding synthetic rather than live customer data.
- 04 **Chen:** Yes. A is <sup>2</sup> \_\_\_\_\_, while B has no route from the internet in this case. That changes the immediate exposure even before we discuss the bulletin.
- 05 **Petra:** The bulletin says the gateway flaw has been used against other organizations. Does that mean we should announce an incident in our own environment?
- 06 **Chen:** No. It establishes <sup>3</sup> \_\_\_\_\_, not local compromise. We should preserve that distinction while using the verified information as a reason to prioritize corrective work.
- 07 **Petra:** Fine, A first. Can we leave B assigned and visible? I do not want lower priority to turn into nobody owning the test-server fix.
- 08 **Chen:** Keep it in the <sup>4</sup> \_\_\_\_\_ queue. The ordering is A first under our agreed rule, not A matters and B never matters. Both need an accountable path.
- 09 **Petra:** A patch is available for each. The gateway update may interrupt production, so we still need the service team involved in timing and checks.
- 10 **Chen:** Obtain the required <sup>5</sup> \_\_\_\_\_. Prioritizing A does not prove the update is compatible or authorize an unplanned production interruption. We need the relevant testing and operational coordination.

# The conversation, continued

## E Conversations / turns 11-20

03

Continue with the word bank on page 28.

- 11 **Petra:** Then my ticket will say selected first, patch available, testing and approval pending. I will not mark it resolved just because we found an update.
- 12 **Chen:** Good. The <sup>6</sup> \_\_\_\_\_ should cover the relevant existing service behavior. A security correction still needs evidence that the planned change works in the required environment.
- 13 **Petra:** If we cannot deploy immediately, the service owner may propose a temporary control. I want the wording to make clear what that would actually achieve.
- 14 **Chen:** Describe it as a <sup>7</sup> \_\_\_\_\_ with a defined scope and verification. Do not claim that reducing one access path automatically corrects the underlying software or removes every route.
- 15 **Petra:** Any delay would need the owner, rationale, and review conditions required by our process. An informal note saying accepted would be too vague.
- 16 **Chen:** Exactly. Formal <sup>8</sup> \_\_\_\_\_ is not something the analyst can invent to clear the queue. It must follow the assigned authority and state what remains exposed.
- 17 **Petra:** After installation, what evidence do you need to close the finding? I can attach the change record, but we still need to verify the affected condition.
- 18 **Chen:** Attach the <sup>9</sup> \_\_\_\_\_ to the record. The person reviewing completion should see why the affected condition is considered resolved, not just that someone ran an installer.
- 19 **Petra:** My summary is A first for demonstrated exploitation and external exposure, B still open, and no local exploitation confirmed. The change steps remain required.
- 20 **Chen:** That makes the <sup>10</sup> \_\_\_\_\_ and exposure visible alongside severity. We can justify urgency without exaggerating the evidence or treating the score as the whole decision.

### ANSWERS / EXPLANATIONS: PAGE 90

1. base score | 2. internet-facing | 3. exploitation in the wild | 4. remediation | 5. change approval | 6. regression test | 7. mitigation | 8. risk acceptance | 9. closure evidence | 10. asset criticality

# A high priority is not completed work

## F Say it

Findings X and Y have equal base scores. X is internet-facing with verified exploitation elsewhere; Y is isolated. The local rule selects X first. Its patch is available, but deployment has not started.

Complete the four gaps. Use each bank entry once.

### WORD + PHRASE BANK

X / equal / pending / elsewhere

Analyst: "The first priority is <sup>1</sup> \_\_\_\_\_."

Owner: "The base scores are <sup>2</sup> \_\_\_\_\_."

Analyst: "Exploitation is verified <sup>3</sup> \_\_\_\_\_."

Owner: "Deployment is still <sup>4</sup> \_\_\_\_\_."

### ANSWERS / EXPLANATIONS: PAGE 90

1. X | 2. equal | 3. elsewhere | 4. pending

## Rehearse with a fixed script

1. Read turns 1-10. Stress equal scores, different exposure, and exploitation elsewhere.
2. Switch roles for turns 11-20. Keep available, deployed, and verified distinct.
3. Check the transfer. Read the priority without claiming a confirmed local compromise.

### WORKING ALONE

Read both roles, pausing for two seconds when the speaker changes. Repeat with the bank covered, then check any missed expressions.

# Support needs logs, not a shared administrator

## A Read the situation

04

**Negotiate a specific access arrangement using identity, task, permission, duration, approval, and accountability.**

Vendor coordinator Eva requests a shared administrator account so two technicians can diagnose a service issue. Access reviewer Rashid confirms that the supplied task needs only read access to sanitized diagnostic logs for two hours. Their local policy requires named identities, multifactor authentication, owner approval, and recorded expiry. No approval has been granted. The proposed alternative gives each technician only the required log access. Any later write task needs a separate assessed request; no broader privilege is justified by the present facts.

PEOPLE / Eva: Vendor coordinator | Rashid: Access reviewer

### OFFER A WORKABLE BOUNDARY

A useful access challenge connects the restriction to the task and offers a precise alternative. Avoid sounding as though vendor status itself makes someone untrustworthy. Explain which requested permissions are unnecessary and how the legitimate work can proceed through the approved route.

## Briefing checks

Circle one answer in each item. Use the briefing.

### 1. What does the diagnostic task require?

- |                                                      |                                               |
|------------------------------------------------------|-----------------------------------------------|
| <b>A</b> Read access to sanitized logs for two hours | <b>B</b> Permanent administrator access       |
| <b>C</b> A shared password for all staff             | <b>D</b> Unrestricted production write access |

### 2. Which local requirement is explicit?

- |                                                                                 |                                                     |
|---------------------------------------------------------------------------------|-----------------------------------------------------|
| <b>A</b> Named identities with multifactor authentication, approval, and expiry | <b>B</b> Anonymous access if the vendor is familiar |
| <b>C</b> No review for short tasks                                              | <b>D</b> Automatic approval after a request         |

### 3. What is the current approval status?

- |                                                     |                                              |
|-----------------------------------------------------|----------------------------------------------|
| <b>A</b> Not granted                                | <b>B</b> Granted by the request alone        |
| <b>C</b> Unnecessary because the logs are sanitized | <b>D</b> Permanent approval for future tasks |

Answers and explanations: page 91.

# The vocabulary that does the work

## B Find the words / 1 of 2

Read the definitions and say the common word combinations aloud.

### identity and access management

Processes for managing identities and their permissions.

**IN USE review identity and access management**

### least privilege

Limiting access to what the authorized task requires.

**IN USE apply least privilege**

### named account

An account associated with an identified individual.

**IN USE provision a named account**

### shared account

An account used by more than one individual.

**IN USE review shared-account risk**

### privileged access

Permission to perform elevated system actions.

**IN USE control privileged access**

### read-only access

Permission to view data without changing it.

**IN USE grant read-only access**

### entitlement

A specific right or permission assigned to an identity.

**IN USE review entitlements**

### role-based access

Permissions assigned through defined job or task roles.

**IN USE configure role-based access**

### multifactor authentication

Verification using more than one distinct factor type.

**IN USE require multifactor authentication**

### single sign-on

Access to multiple services through a shared sign-in arrangement.

**IN USE support single sign-on**

### federation

Trust between identity systems to support identity assertions.

**IN USE configure identity federation**

### provisioning

Creating or enabling an identity or its access.

**IN USE complete access provisioning**

### Precision check

Authentication checks identity; authorization controls permitted actions. Multifactor authentication does not by itself justify administrator rights. Sanitization also does not remove the stated approval, identity, and expiry requirements.

# The vocabulary that does the work

## B Find the words / 2 of 2

Read the definitions and say the common word combinations aloud.

### deprovisioning

Removing or disabling access that is no longer needed.

**IN USE** verify deprovisioning

### access review

Evaluation of whether granted rights remain appropriate.

**IN USE** conduct an access review

### time-bound access

Permission with a defined end time or duration.

**IN USE** approve time-bound access

### expiry

The point at which a permission or approval ends.

**IN USE** record access expiry

### just-in-time access

Access activated only for an approved period of need.

**IN USE** request just-in-time access

### standing privilege

Elevated access retained beyond a particular active task.

**IN USE** reduce standing privilege

### session record

Information documenting a particular access session.

**IN USE** review session records

### accountability

Ability to associate actions with responsible identities.

**IN USE** preserve individual accountability

### separation of duties

Dividing sensitive responsibilities to reduce conflicting control.

**IN USE** maintain separation of duties

### break-glass access

Controlled emergency access outside the normal route.

**IN USE** govern break-glass access

### service account

An identity used by a service or automated process.

**IN USE** manage service-account permissions

### sanitized logs

Diagnostic records with restricted details removed or protected.

**IN USE** share sanitized logs

### Precision check

A two-hour read-only task supports a bounded proposal, not automatic approval. If the work later changes, reassess the additional permission instead of silently extending the original scope.

# Phrases you can actually use

## **C** Notice the language / 1 of 2

### **ACKNOWLEDGE THE SUPPORT NEED**

"We need to enable the diagnostic work."

### **USE THE SUPPLIED SCOPE**

"The task only needs sanitized diagnostic logs."

### **PRESERVE IDENTITY**

"Each technician needs a named account."

### **BOUND THE DURATION**

"The requested access lasts two hours."

### **CLARIFY THE TASK**

"Which action requires administrator rights?"

### **OFFER NARROWER ACCESS**

"Read-only access supports that task."

### **STATE THE LOCAL CONDITION**

"Multifactor authentication is required."

### **KEEP APPROVAL EXPLICIT**

"The service owner has not approved it yet."

---

### **Need**

Link the permission to an actual task.

### **Shared**

Can weaken individual attribution when people use one identity.

### **Read-only**

Still requires appropriate handling and approval.

# Phrases you can actually use

## C Notice the language / 2 of 2

### PROTECT ACCOUNTABILITY

"We need to associate actions with each technician."

### NAME EXPIRY

"Record when the access ends."

### AVOID A PERSONAL JUDGMENT

"The restriction follows the task, not a judgment about the vendor."

### CONFIRM REMOVAL

"Verify that access ends as approved."

### AVOID STANDING ACCESS

"This request does not justify permanent privilege."

### SEPARATE FUTURE WORK

"A later write task needs a new assessed request."

### ASK FOR EVIDENCE

"Please include the task, identities, and duration."

### CLOSE THE PROPOSAL

"Submit named, read-only, time-bound access for owner review."

---

### Temporary

Needs an explicit end, not an informal expectation.

### Approved

Distinguish a proposal from a recorded decision.

### More access

Requires a reason beyond convenience or a possible future task.

# Choose the precise message

## **D** Check your understanding

Circle one best answer for each item. Use the stated purpose and case facts, not the option that merely sounds most polite.

### 1. Which proposal best matches the supplied task and policy?

- A** Named read-only log access for two hours, with MFA and owner approval
- B** Shared read-only log access for two hours, with MFA and owner approval
- C** Named administrator access for two hours, with MFA and owner approval
- D** Named read-only log access with MFA and owner approval, without an expiry

### 2. Why does MFA not settle the request?

- A** It strengthens identity verification but does not justify unnecessary permissions.
- B** It guarantees every requested action is appropriate.
- C** It replaces the need for named identities in this policy.
- D** It means the account can never be misused.

### 3. What should happen if a write task emerges?

- A** Submit the additional need for a separate assessment.
- B** Quietly add write access to the original request.
- C** Treat all future tasks as already approved.
- D** Reuse a shared administrator password without a record.

### 4. Which explanation avoids blaming the vendor?

- A** The task requires log reading, so we are proposing only that access.
- B** Vendors always misuse administrator accounts.
- C** Familiar technicians never need access review.
- D** We are refusing all support without reviewing the task.

Answers and explanations: [page 91](#).

# Support needs logs, not a shared administrator

## E Conversations / turns 1-10

04

Complete the numbered gaps. Use each bank entry once, without changing its form. Cover the answers at the end until you finish.

### WORD + PHRASE BANK

time-bound access / Accountability / deprovisioning / Provisioning / named account / entitlement / least privilege / read-only access / multifactor authentication / expiry

- 01 **Eva:** Two vendor technicians need to investigate the service issue. They asked for a shared administrator account so either person can begin when available.
- 02 **Rashid:** Let us start with <sup>1</sup> \_\_\_\_\_. The supplied task needs read access to sanitized diagnostic logs for two hours. Which part requires changing the system or administering it?
- 03 **Eva:** None of the documented diagnostic steps requires a write. They want to inspect the logs and compare the recorded errors with their product knowledge.
- 04 **Rashid:** Then propose <sup>2</sup> \_\_\_\_\_. That supports the described work without granting unrelated administrative rights. We should make the permitted action clear in the request.
- 05 **Eva:** They will take turns during the two hours. Can one account cover both, or do we need two identities even for that short window?
- 06 **Rashid:** Our policy requires a <sup>3</sup> \_\_\_\_\_ for each technician. A private agreement about sharing does not replace individual attribution or the access conditions we have been asked to enforce.
- 07 **Eva:** I will collect both identities. The vendor also says their ordinary login is secure. Does that satisfy our sign-in requirement for this request?
- 08 **Rashid:** We require <sup>4</sup> \_\_\_\_\_. We need to verify that the approved arrangement meets it, not rely on the general adjective secure or treat vendor familiarity as an exemption.
- 09 **Eva:** That gives me the identity and sign-in requirements. For timing, I can specify a two-hour window rather than leaving the access available indefinitely.
- 10 **Rashid:** Make it <sup>5</sup> \_\_\_\_\_ with a recorded end. Short work does not justify standing privilege, and the duration should be visible to whoever reviews and implements the request.

# The conversation, continued

## E Conversations / turns 11-20

04

Continue with the word bank on page 37.

- 11 **Eva:** I have submitted the request, but the owner has not signed off. What can I tell the technicians while that decision is pending?
- 12 **Rashid:** Correct. <sup>6</sup> \_\_\_\_\_ follows the required approval. A well-scoped request is ready for review; it does not authorize itself simply because the proposed permissions are narrow.
- 13 **Eva:** If their diagnosis later shows that a configuration change is needed, I will ask them to describe the new action and why it is necessary.
- 14 **Rashid:** That is a new <sup>7</sup> \_\_\_\_\_ question. Do not silently add write access to a request justified only by log reading. The additional need must go through its own assessment.
- 15 **Eva:** I can explain that this is about fitting access to work, not suggesting that the technicians intend to misuse anything. We still want their support.
- 16 **Rashid:** Exactly. <sup>8</sup> \_\_\_\_\_ also protects legitimate work by showing who did what. Neutral language makes that purpose clearer than a blanket statement that vendors are risky.
- 17 **Eva:** I will put the identities, read-only log scope, multifactor requirement, two-hour duration, and owner decision in the request. What should I say about the end?
- 18 **Rashid:** Record the <sup>9</sup> \_\_\_\_\_ and confirm how it will be enforced. The access should not remain active simply because everyone assumes somebody else will remove it later.
- 19 **Eva:** Then I will send the bounded proposal for owner review and avoid promising administrator access. Any changed task will return with a specific justification.
- 20 **Rashid:** Good. Verify <sup>10</sup> \_\_\_\_\_ when the approved window ends. We can enable the diagnostic work while keeping permission, duration, approval, and individual responsibility explicit.

### ANSWERS / EXPLANATIONS: PAGE 92

1. least privilege | 2. read-only access | 3. named account | 4. multifactor authentication | 5. time-bound access | 6. Provisioning | 7. entitlement | 8. Accountability | 9. expiry | 10. deprovisioning

# The task sets the boundary

## F Say it

A technician needs to view sanitized logs for three hours. Local policy requires a named identity, MFA, owner approval, and expiry. Approval is still pending; no write task is supplied.

Complete the four gaps. Use each bank entry once.

### WORD + PHRASE BANK

named / three / pending / read-only

Coordinator: "The requested permission is <sup>1</sup> \_\_\_\_\_."

Reviewer: "The requested duration is <sup>2</sup> \_\_\_\_\_ hours."

Coordinator: "The identity must be <sup>3</sup> \_\_\_\_\_."

Reviewer: "Owner approval remains <sup>4</sup> \_\_\_\_\_."

### ANSWERS / EXPLANATIONS: PAGE 92

1. read-only | 2. three | 3. named | 4. pending

## Rehearse with a fixed script

1. Read turns 1-10. Contrast read-only access with administrator rights.
2. Switch roles for turns 11-20. Stress pending approval and the recorded expiry.
3. Check the transfer. Read the three-hour proposal as a request, not an approval.

### WORKING ALONE

Read both roles, pausing for two seconds when the speaker changes. Repeat with the bank covered, then check any missed expressions.

# A sign-in check does not decide document access

## A Read the situation

05

**Trace a data flow, identify a trust boundary, and turn a specific abuse case into a testable design requirement.**

Architect Noor and security engineer Daniel review a fictional document portal. A signed-in browser sends a document ID to a service, which retrieves a file from storage. The draft checks the user at sign-in but does not specify a server-side check that the user may access the requested document. Customers must see only their own organization-owned documents. The review has no implemented-system test result or confirmed breach. Daniel proposes a per-request authorization check and an approved test using separate fictional tenant accounts.

PEOPLE / Noor: Application architect | Daniel: Security engineer

### CHALLENGE THE ASSUMPTION, NOT THE DESIGNER

A useful design challenge names the specific request, boundary, and missing decision. It does not accuse the architect of causing a breach. Distinguish a documented design gap from an observed production defect while making the next requirement concrete.

## Briefing checks

Circle one answer in each item. Use the briefing.

1. What does the supplied draft already check?

- A Authorization for every requested document
- C The outcome of an implemented-system test

- B That every customer owns every file
- D The user at sign-in

2. What security requirement is supplied?

- A Every signed-in user may read every document.
- C A document ID grants access by itself.

- B Storage may trust every browser-supplied identifier.
- D Customers may see only their own organization-owned documents.

3. What is not established?

- A A confirmed breach or implemented-system test result
- C The use of document identifiers

- B The existence of browser requests
- D The need to restrict documents by organization

Answers and explanations: [page 93](#).

# The vocabulary that does the work

## B Find the words / 1 of 2

Read the definitions and say the common word combinations aloud.

### threat model

A structured account of relevant threats and responses.

**IN USE review the threat model**

### data flow

Movement of information between system elements.

**IN USE trace the data flow**

### trust boundary

A point where assumptions about control or trust change.

**IN USE identify a trust boundary**

### external entity

An actor or system outside the modeled component.

**IN USE identify external entities**

### process

A component that transforms or acts on data.

**IN USE model the service process**

### data store

A location where information is retained.

**IN USE identify data stores**

### asset

Something of value requiring protection.

**IN USE identify sensitive assets**

### entry point

A place where data or interaction enters a system.

**IN USE review entry points**

### abuse case

A scenario describing misuse of intended functionality.

**IN USE define an abuse case**

### security requirement

A checkable condition protecting a security objective.

**IN USE specify a security requirement**

### authentication check

A check of the claimed identity.

**IN USE perform an authentication check**

### authorization check

A check of permission for a requested action.

**IN USE enforce an authorization check**

### Precision check

Identity and object permission are different decisions. A legitimate user may still request a document belonging to another organization. The design must specify where that permission is enforced, not merely that sign-in exists.

# The vocabulary that does the work

## B Find the words / 2 of 2

Read the definitions and say the common word combinations aloud.

### object-level authorization

Permission enforcement for a specific requested object.

**IN USE** verify object-level authorization

### tenant

A customer or organization sharing a service.

**IN USE** isolate tenant data

### tenant isolation

Separation preventing unauthorized cross-tenant access.

**IN USE** test tenant isolation

### server-side enforcement

A decision enforced by the service rather than the client.

**IN USE** require server-side enforcement

### untrusted input

Data not accepted as authoritative without validation.

**IN USE** handle untrusted input

### document identifier

A value used to refer to a specific document.

**IN USE** validate the document identifier

### STRIDE

Spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege.

**IN USE** apply STRIDE categories

### spoofing

Misrepresenting an identity or source.

**IN USE** assess spoofing threats

### tampering

Unauthorized modification of data or system state.

**IN USE** prevent data tampering

### information disclosure

Exposure of information to an unauthorized party.

**IN USE** prevent information disclosure

### denial of service

Disruption of access to a service or resource.

**IN USE** assess denial-of-service risk

### elevation of privilege

Gaining rights beyond the permitted level.

**IN USE** prevent elevation of privilege

### Precision check

This is a design review, not proof of a breach. The proposed test belongs in an approved environment with controlled test accounts and data. A passing identity check alone does not satisfy the document-access requirement.

# Phrases you can actually use

## C Notice the language / 1 of 2

### START WITH THE REQUEST

"The browser sends a document identifier to the service."

### NAME THE BOUNDARY

"The client-provided identifier crosses a trust boundary."

### IDENTIFY THE MISSING DECISION

"It does not specify permission for this document."

### KEEP THE CLAIM BOUNDED

"We have a design gap, not a confirmed breach."

### TRACE THE NEXT STEP

"The service retrieves the file from storage."

### ACKNOWLEDGE THE EXISTING CHECK

"The draft checks identity at sign-in."

### STATE THE PROTECTED OUTCOME

"Customers must see only their own organization's documents."

### MAKE THE ABUSE CASE CONCRETE

"A signed-in user requests another tenant's document."

---

## Authenticated

Does not mean authorized for every object.

## Missing in the draft

Not the same as proven absent in the implementation.

## Trust

State which input or claim is being relied upon.

# Phrases you can actually use

## C Notice the language / 2 of 2

### PLACE ENFORCEMENT

"The permission check belongs on the server for each request."

### DEFINE THE DENIED CASE

"The service must deny access when the document is outside the user's permitted scope."

### USE CONTROLLED TESTING

"Use approved test accounts and fictional documents."

### SEPARATE CATEGORIES

"This case concerns unauthorized disclosure of document content."

### REJECT CLIENT TRUST

"A browser-supplied identifier is not authorization."

### PRESERVE LEGITIMATE WORK

"The allowed same-tenant request must still work."

### ASSIGN THE REQUIREMENT

"Add the access condition to the design and tests."

### CLOSE THE REVIEW

"Record the requirement, its owner, and the validation evidence needed."

---

## Per request

Check the action each time under the intended rule.

## Deny

Specify the condition and observable protected outcome.

## Test

Must have approved scope, controlled data, and a clear expected result.

# Choose the precise message

## **D** Check your understanding

Circle one best answer for each item. Use the stated purpose and case facts, not the option that merely sounds most polite.

### 1. Which requirement closes the identified design gap?

- A** Enforce server-side permission for each requested document.
- B** Require sign-in and then trust every document ID.
- C** Hide the document ID in the page while omitting server checks.
- D** Treat every authenticated user as a storage administrator.

### 2. Which pair best tests the stated boundary?

- A** A search of live customer documents without approval
- B** An authorized same-tenant request and a denied cross-tenant request using controlled data
- C** Two requests by the same owner for the same file only
- D** A page color check and a logo check

### 3. Which statement overclaims the review evidence?

- A** A customer breach has definitely occurred.
- B** The draft lacks a specified document-permission check.
- C** A sign-in check is described.
- D** The design needs a testable access condition.

### 4. Why is a browser-supplied ID not enough?

- A** Storage ownership changes when a URL is typed.
- B** Authentication makes object checks unnecessary.
- C** A value naming an object does not establish permission to access it.
- D** Every identifier is automatically secret forever.

Answers and explanations: [page 93](#).

# A sign-in check does not decide document access

## E Conversations / turns 1-10

05

Complete the numbered gaps. Use each bank entry once, without changing its form. Cover the answers at the end until you finish.

### WORD + PHRASE BANK

abuse case / server-side enforcement / trust boundary / authorization check / information disclosure / tenant isolation / data flow / threat model / security requirement / object-level authorization

- 01 **Noor:** The diagram lists the browser, service, and storage. We require sign-in before the document page, so I thought the main access question was covered.
- 02 **Daniel:** Let us trace the <sup>1</sup> \_\_\_\_\_. A browser sends a document identifier, the service processes it, and storage returns content. Where is permission for that particular document checked?
- 03 **Noor:** The draft does not say. It describes checking the user at sign-in, then retrieving the requested file. Our customers should see only their own organization's documents.
- 04 **Daniel:** That leaves an <sup>2</sup> \_\_\_\_\_ unspecified. We know who signed in, but we still need the service to decide whether that user may access the requested object.
- 05 **Noor:** So the gap is not simply that somebody could be anonymous. It also concerns a legitimate user asking for a document outside their organization.
- 06 **Daniel:** Exactly. That is the <sup>3</sup> \_\_\_\_\_ we should record. It makes the missing decision concrete without claiming that the implemented system has already leaked anything or that a breach occurred.
- 07 **Noor:** Could we just hide documents from other organizations in the browser? Or does the service need to enforce the same boundary independently?
- 08 **Daniel:** The client crosses a <sup>4</sup> \_\_\_\_\_. A page convention does not give the server a dependable authorization decision. We need enforcement where the service controls access to the content.
- 09 **Noor:** Then the requirement should say the service checks permission on every request, using the authenticated user's allowed organization scope and the requested document.
- 10 **Daniel:** Yes, that is <sup>5</sup> \_\_\_\_\_. The service must deny access when the document is outside that permitted scope, while keeping the legitimate same-tenant request working.

# The conversation, continued

## E Conversations / turns 11-20

Continue with the word bank on page 46.

05

- 11 **Noor:** I will put both outcomes into the design. Otherwise someone could call the issue fixed by denying every request and breaking the ordinary feature.
- 12 **Daniel:** Good. A useful <sup>6</sup> \_\_\_\_\_ is checkable and preserves intended use. We should identify the denied case and the allowed case instead of saying only make document access secure.
- 13 **Noor:** For validation, we can use two fictional organizations with controlled test accounts and documents in the approved environment. No live customer exploration is needed.
- 14 **Daniel:** That supports a <sup>7</sup> \_\_\_\_\_ check within an authorized scope. Record which account owns which document, the requested action, and the expected result before interpreting the observed outcome.
- 15 **Noor:** What label goes in the review: confirmed vulnerability or design gap? We have a draft in front of us, not an implementation test.
- 16 **Daniel:** Keep the <sup>8</sup> \_\_\_\_\_ precise: documented design gap, proposed requirement, validation pending. We should not manufacture certainty, but the lack of a live failure does not erase the gap.
- 17 **Noor:** I will assign the requirement to the service owner and include the browser input, storage ownership, and access-decision location in the revised diagram.
- 18 **Daniel:** Make <sup>9</sup> \_\_\_\_\_ explicit. The next reviewer should not have to guess whether the note describes a user-interface preference or an actual control over returned content.
- 19 **Noor:** The review record will distinguish the existing sign-in check, missing per-document rule, proposed controlled tests, and evidence still needed before we close the action.
- 20 **Daniel:** That is clear. The relevant harm here is <sup>10</sup> \_\_\_\_\_, and the response is a defined access decision. We have moved from a technology list to a reviewable requirement without overstating the evidence.

### ANSWERS / EXPLANATIONS: PAGE 94

1. data flow | 2. authorization check | 3. abuse case | 4. trust boundary | 5. object-level authorization | 6. security requirement | 7. tenant isolation | 8. threat model | 9. server-side enforcement | 10. information disclosure

# Identity is not object permission

## F Say it

A design checks identity at sign-in but omits permission checks for individual invoices. Customers may access only their own invoices. No implementation test has run. The proposed control belongs in the service.

Complete the four gaps. Use each bank entry once.

### WORD + PHRASE BANK

authorization / server / identity / pending

Architect: "The existing check establishes <sup>1</sup> \_\_\_\_\_."

Security: "Each invoice also needs an <sup>2</sup> \_\_\_\_\_ check."

Architect: "Enforcement belongs on the <sup>3</sup> \_\_\_\_\_."

Security: "Implementation validation remains <sup>4</sup> \_\_\_\_\_."

### ANSWERS / EXPLANATIONS: PAGE 94

1. identity | 2. authorization | 3. server | 4. pending

## Rehearse with a fixed script

1. Read turns 1-10. Stress identity and document permission as separate decisions.
2. Switch roles for turns 11-20. Keep design evidence distinct from an implementation test.
3. Check the transfer. Read identity, authorization, and server as different parts of the control.

### WORKING ALONE

Read both roles, pausing for two seconds when the speaker changes. Repeat with the bank covered, then check any missed expressions.

# A written policy does not close the control finding

## A Read the situation

**Describe audit evidence, distinguish missing proof from proven failure, and state the actual closure conditions.**

06

Control owner Rosa asks auditor Amir to close a leaver-access finding because a new policy was approved. The local control requires access removal within 24 hours of departure. In a five-person sample, three records prove timely removal; two lack removal timestamps. The agreed closure criteria require evidence for all five sampled cases and owner review. That review is not recorded. Amir must distinguish a documentation gap from proof that the two removals were late, while keeping the finding open.

PEOPLE / Rosa: Control owner | Amir: Internal auditor

### MAKE THE EVIDENCE REQUEST SPECIFIC

A challenge to closure need not dismiss the work already completed. Acknowledge the approved policy, then name the missing records and review. Avoid both extremes: treating paperwork as operating proof or calling every undocumented action a proven late removal.

## Briefing checks

Circle one answer in each item. Use the briefing.

1. How many sampled records prove timely removal?

A Two of five

B None, because no policy exists

C Three of five

D Five of five

2. What do the other two records lack?

A Employee names in every case

B A rule requiring access removal

C Proof that a policy was approved

D Removal timestamps

3. Can the finding close under the supplied criteria?

A No; the briefing proves every removal was late.

B No; evidence and owner review are incomplete.

C Yes; a written policy replaces all operating evidence.

D Yes; three records prove every removal was timely.

Answers and explanations: [page 95](#).

# The vocabulary that does the work

## B Find the words / 1 of 2

Read the definitions and say the common word combinations aloud.

### **governance**

Arrangements for directing decisions, responsibilities, and oversight.

**IN USE strengthen security governance**

### **control objective**

The outcome a control is intended to achieve.

**IN USE define the control objective**

### **control design**

The planned way a control is meant to work.

**IN USE assess control design**

### **operating effectiveness**

Whether a control works as intended over the assessed scope.

**IN USE test operating effectiveness**

### **policy**

An approved statement of required principles or rules.

**IN USE approve an access policy**

### **procedure**

Defined steps for carrying out a process.

**IN USE maintain the removal procedure**

### **control owner**

The role accountable for a defined control.

**IN USE identify the control owner**

### **evidence request**

A specified request for records supporting an assessment.

**IN USE issue an evidence request**

### **audit trail**

Records allowing actions and decisions to be traced.

**IN USE preserve the audit trail**

### **sample**

A selected subset examined in an assessment.

**IN USE define the audit sample**

### **population**

The full set from which assessment items are selected.

**IN USE establish the population**

### **sampling limitation**

A restriction on what a sample supports about the wider set.

**IN USE disclose sampling limitations**

### **Precision check**

Three of five is 60% of the sample with documented timely removal. It is not a demonstrated 60% organization-wide effectiveness rate. The two missing timestamps do not establish whether those removals were timely or late.

# The vocabulary that does the work

## **B** Find the words / 2 of 2

Read the definitions and say the common word combinations aloud.

### exception

A departure from a defined requirement or expected condition.

**IN USE** investigate an exception

### evidence gap

Missing support needed to substantiate a conclusion.

**IN USE** resolve an evidence gap

### finding

A documented assessment issue supported by stated criteria and evidence.

**IN USE** track an audit finding

### remediation plan

Agreed work to address an identified finding.

**IN USE** review the remediation plan

### closure criterion

A stated condition required to close an action.

**IN USE** satisfy closure criteria

### attestation

A formal statement affirming a specified matter.

**IN USE** obtain an owner attestation

### independent review

Assessment by a sufficiently separate reviewer.

**IN USE** conduct an independent review

### retention period

The required duration for keeping records.

**IN USE** apply the retention period

### control frequency

How often a control is intended to operate.

**IN USE** specify control frequency

### leaver process

Handling required when a person leaves an organization.

**IN USE** verify the leaver process

### access removal

Disabling or withdrawing previously granted permissions.

**IN USE** evidence timely access removal

### residual risk

Risk remaining after the relevant controls or treatment.

**IN USE** assess residual risk

06

### Precision check

Policy approval supports the existence of a rule. Operating evidence supports what happened in practice. The supplied closure conditions require all five sampled cases and recorded owner review, so the finding remains open.

# Phrases you can actually use

## C Notice the language / 1 of 2

### ACKNOWLEDGE PROGRESS

"The new policy has been approved."

### SEPARATE DESIGN FROM OPERATION

"That does not yet establish operating effectiveness."

06

### STATE THE CRITERION

"Access removal is required within 24 hours."

### GIVE THE SUPPORTED COUNT

"Three of five records prove timely removal."

### NAME THE MISSING EVIDENCE

"Two records lack removal timestamps."

### AVOID A FALSE FAILURE CLAIM

"We cannot determine timeliness for those two from these records."

### LIMIT THE PERCENTAGE

"Sixty percent of this sample has documented timely removal."

### PRESERVE THE CLOSURE RULE

"The agreed criteria require evidence for all five cases."

---

## Written

Establishes a document exists, not that people followed it.

## Timely

Needs both a defined deadline and relevant event evidence.

## Undocumented

Does not automatically mean not done.

# Phrases you can actually use

## C Notice the language / 2 of 2

### ASK FOR THE REVIEW

"Please provide the recorded owner review."

### REQUEST TRACEABLE SUPPORT

"Use the relevant system evidence and identify its source."

### KEEP THE STATUS ACCURATE

"The finding remains open pending the missing evidence."

### ASSIGN THE NEXT STEP

"The control owner will gather the missing records."

### AVOID RETROACTIVE INVENTION

"Do not create a timestamp as though it were an original record."

### DISTINGUISH ASSURANCE

"An assurance statement is not a substitute for the required record."

### BOUND THE CONCLUSION

"This sample does not establish the result for the entire population."

### CLOSE THE DISCUSSION

"We will reassess closure against the same agreed criteria."

06

---

## Sample

State its size and avoid unwarranted population claims.

## Closed

A conclusion under stated criteria, not a reward for effort.

## Attest

Make clear what is affirmed and what evidence remains required.

# Choose the precise message

## **D** Check your understanding

Circle one best answer for each item. Use the stated purpose and case facts, not the option that merely sounds most polite.

### 1. Which summary is accurate?

- A** Sixty percent of all employees were removed on time.
- B** Three timely removals are evidenced; two are unverified; owner review is missing.
- C** All five removals are proven timely because the policy exists.
- D** Two late removals are proven by missing timestamps.

### 2. What is 3 divided by 5 in this case?

- A** 60% organization-wide control effectiveness
- B** A 60% proven late-removal rate
- C** Proof that the two undocumented cases were timely
- D** 60% of the sample with documented timely removal

### 3. Which evidence request is appropriately specific?

- A** Replace the missing timestamps with estimates presented as original records.
- B** Repeat the policy approval date as proof of all removals.
- C** Provide source records for the two removal times and the owner review.
- D** Please send anything that looks reassuring.

### 4. Why should the finding remain open?

- A** A new policy can never support a control.
- B** Every missing record proves deliberate misconduct.
- C** The auditor dislikes the control owner.
- D** The agreed evidence and review conditions are not met.

Answers and explanations: [page 95](#).

# A written policy does not close the control finding

## E Conversations / turns 1-10

Complete the numbered gaps. Use each bank entry once, without changing its form. Cover the answers at the end until you finish.

06

### WORD + PHRASE BANK

sample / remediation plan / attestation / operating effectiveness / evidence gap / control owner / control design / closure criteria / audit trail / sampling limitation

- 01 **Rosa:** The new leaver policy is approved. It requires removal within twenty-four hours, and I would like the audit action marked closed before the committee meeting.
- 02 **Amir:** Policy approval is useful progress on <sup>1</sup> \_\_\_\_\_, but closure also requires evidence that the control operated. Let us compare the supplied records with the criteria we agreed.
- 03 **Rosa:** We selected five leavers. Three records include departure and removal times within the required period. The other two do not include removal timestamps.
- 04 **Amir:** Then <sup>2</sup> \_\_\_\_\_ is not established for all five. We should not describe the policy document as if it were evidence of each actual removal.
- 05 **Rosa:** Could I say the control was sixty percent effective? Three out of five is sixty percent, and that seems more concise for the committee.
- 06 **Amir:** Report the <sup>3</sup> \_\_\_\_\_ accurately: sixty percent has documented timely removal. That does not establish organization-wide effectiveness, and it does not prove the other two were late.
- 07 **Rosa:** I agree about not calling them late without evidence. The help desk thinks the removals happened, but we do not yet have the original supporting records.
- 08 **Amir:** That is an <sup>4</sup> \_\_\_\_\_. Request the relevant system records and identify their source. A recollection can guide the search, but it should not become an invented historical timestamp.
- 09 **Rosa:** The closure note says evidence for every sampled case and owner review. I have not completed a recorded review because the two records are still missing.
- 10 **Amir:** Those are the <sup>5</sup> \_\_\_\_\_ we must use. The finding remains open until the missing support and required review are addressed, rather than closing merely because the policy now exists.

# The conversation, continued

## E Conversations / turns 11-20

Continue with the word bank on page 55.

- 11 **Rosa:** The committee will ask why it is still open. Can we show the approved policy and three supported cases without implying the remaining work is done?
- 12 **Amir:** Show that in the <sup>6</sup> \_\_\_\_\_. Completed work and an open finding can coexist. A progress update should say what changed and what still prevents the agreed closure.
- 13 **Rosa:** I will assign the record retrieval and keep the committee wording bounded. For the missing cases, I will use timeliness unverified rather than late.
- 14 **Amir:** That preserves the <sup>7</sup> \_\_\_\_\_. We need a traceable account of the assessment, including any later records or corrections, not a headline that hides unresolved support.
- 15 **Rosa:** Could I sign a statement about our normal process? I can describe what the team does, but I cannot supply those two times yet.
- 16 **Amir:** An <sup>8</sup> \_\_\_\_\_ may be relevant context, but it does not replace the specific records required here. We should not silently change the closure standard at the end.
- 17 **Rosa:** Understood. I will separate approval of the policy, evidence for three timely removals, two unverified cases, and the owner review still to be recorded.
- 18 **Amir:** Also state the <sup>9</sup> \_\_\_\_\_. We examined five records; we have not established the result for every leaver. The percentage needs both its denominator and its evidence meaning.
- 19 **Rosa:** Then I can give the committee a truthful progress report and a clear remaining action, without claiming that missing documentation proves misconduct or lateness.
- 20 **Amir:** Exactly. The <sup>10</sup> \_\_\_\_\_ can bring the missing evidence for reassessment. We will evaluate closure against the same criteria and record the conclusion the completed support actually justifies.

06

### ANSWERS / EXPLANATIONS: PAGE 96

1. control design | 2. operating effectiveness | 3. sample | 4. evidence gap | 5. closure criteria | 6. remediation plan | 7. audit trail | 8. attestation | 9. sampling limitation | 10. control owner

# Missing proof is not a proven delay

## F Say it

A four-case access-removal sample has three documented timely removals and one missing timestamp. Closure requires evidence for all four and an owner review. Neither the missing evidence nor the review is complete.

Complete the four gaps. Use each bank entry once.

06

### WORD + PHRASE BANK

timeliness / review / closure / timestamp

Auditor: "For the fourth case, we still need the removal <sup>1</sup> \_\_\_\_\_."

Owner: "Without it, I cannot verify that case's <sup>2</sup> \_\_\_\_\_."

Auditor: "We also need the recorded owner <sup>3</sup> \_\_\_\_\_."

Owner: "Keep the finding open until the evidence and review meet our conditions for <sup>4</sup> \_\_\_\_\_."

### ANSWERS / EXPLANATIONS: PAGE 96

1. timestamp | 2. timeliness | 3. review | 4. closure

## Rehearse with a fixed script

1. Read turns 1-10. Contrast three supported cases with two unverified cases.
2. Switch roles for turns 11-20. Stress sample limits and the required owner review.
3. Check the transfer. Read the evidence request without calling the missing case late.

### WORKING ALONE

Read both roles, pausing for two seconds when the speaker changes. Repeat with the bank covered, then check any missed expressions.

# Report the click, without guessing the consequence

## A Read the situation

**Elicit a precise suspicious-message report, encourage prompt disclosure, and avoid requests for secrets or unsupported reassurance.**

Employee Ben calls security responder Leila about an email claiming to be from Payroll. He clicked its link at 09:32 UTC and reported it at 09:36. He says he entered no credentials, opened no attachment, and approved no sign-in prompt. He worries that reporting will get him blamed. The message has not been classified, and compromise is not established. The local process routes the original message through the approved reporting tool. Leila asks for factual details, not passwords, and tells Ben not to interact further while the response team assesses it.

PEOPLE / Ben: Employee reporter | Leila: Security responder

07

### MAKE ACCURATE REPORTING EASIER

Thank the person for reporting and ask neutral, concrete questions about actions. Do not promise immunity from every workplace consequence or declare the device safe without evidence. Reassurance should support truthful disclosure and the reporting process, not substitute for assessment.

## Briefing checks

Circle one answer in each item. Use the briefing.

### 1. What did Ben report doing?

- A** Entering a password and approving every prompt
- B** Downloading an attachment and running it
- C** Confirming that Payroll sent the email
- D** Clicking the link without entering credentials, opening an attachment, or approving a prompt

### 2. How long after the click did Ben report it?

- A** Thirty-six minutes
- B** Four hours
- C** Four minutes
- D** Thirty-two minutes

### 3. What is the message status?

- A** A confirmed breach of every account
- B** Proven harmless because no password was entered
- C** Not yet classified
- D** Confirmed legitimate payroll communication

[Answers and explanations: page 97.](#)

# The vocabulary that does the work

## **B** Find the words / 1 of 2

Read the definitions and say the common word combinations aloud.

### phishing

Deceptive communication intended to induce unsafe disclosure or action.

**IN USE** report suspected phishing

### social engineering

Manipulating people to gain information or access.

**IN USE** recognize social-engineering tactics

### pretext

A claimed reason used to justify a request.

**IN USE** identify the pretext

### impersonation

Pretending to be a trusted person or organization.

**IN USE** assess possible impersonation

### display name

The sender label shown by a message interface.

**IN USE** inspect the display name

### sender address

The address presented as the origin of a message.

**IN USE** verify the sender address

### reply-to address

The destination used when replying to a message.

**IN USE** compare the reply-to address

### message header

Technical metadata associated with an email.

**IN USE** preserve message headers

### link destination

The address to which a link points.

**IN USE** assess the link destination

### attachment

A file included with a message.

**IN USE** report an unexpected attachment

### credential

Information or a token used to support authentication.

**IN USE** protect authentication credentials

### credential harvesting

Deceptively collecting authentication information.

**IN USE** investigate credential harvesting

### Precision check

No credentials entered is important reported information, not proof that no risk exists. Preserve what the employee says as a report until corroborated where needed. Message appearance and a familiar display name do not establish authenticity.

# The vocabulary that does the work

## B Find the words / 2 of 2

Read the definitions and say the common word combinations aloud.

### MFA prompt

A request for an additional authentication step.

**IN USE** report an unexpected MFA prompt

### urgency cue

Language pressuring someone to act quickly.

**IN USE** identify an urgency cue

### out-of-band verification

Checking through a separate trusted communication route.

**IN USE** use out-of-band verification

### known contact channel

A previously verified way to reach a person or team.

**IN USE** use a known contact channel

### reporting tool

An approved mechanism for submitting suspicious content.

**IN USE** use the reporting tool

### reporter

A person who raises a concern or observation.

**IN USE** acknowledge the reporter

### intake

Initial collection of facts for assessment.

**IN USE** complete security intake

### interaction history

A factual account of actions taken with content.

**IN USE** record interaction history

### message classification

An assessed category assigned to a message.

**IN USE** confirm message classification

### compromise

Loss of the intended security of an account or system.

**IN USE** investigate possible compromise

### quarantine

Controlled separation of suspicious content or systems.

**IN USE** verify quarantine status

### reporting delay

Time between a relevant event and its report.

**IN USE** measure reporting delay

### Precision check

The four-minute reporting interval is a fact about this case. Thanking the reporter supports the response, but the responder should not promise an outcome that belongs to another process or declare a clean device without assessment.

# Phrases you can actually use

## **C** Notice the language / 1 of 2

### WELCOME THE REPORT

"Thank you for reporting it promptly."

### LOCATE THE EVENT

"What time did you click the link?"

### PROTECT SECRETS

"Do not tell me your password."

### AVOID PREMATURE REASSURANCE

"We have not established whether there was any compromise."

### ASK NEUTRALLY

"What did you do after opening the message?"

### SEPARATE THE ACTIONS

"Did you enter credentials, open a file, or approve a sign-in prompt?"

### ATTRIBUTE THE ACCOUNT

"You report that no credentials were entered."

### STOP FURTHER INTERACTION

"Do not interact with the message further."

---

### Claimed sender

Not yet an authenticated sender.

### Clicked

Distinguish from entering credentials or opening a file.

### Reported

Attributes the information without overstating verification.

# Phrases you can actually use

## C Notice the language / 2 of 2

### USE THE APPROVED ROUTE

"Submit the original through the reporting tool."

### AVOID ORDINARY FORWARDING

"Use the approved tool, not a wider distribution list."

### NAME THE PRETEXT

"The message claims that payroll action is urgent."

### SUPPORT DISCLOSURE

"Accurate details help us choose the right response."

### PRESERVE RELEVANT DETAILS

"Keep the message details available for the response team."

### VERIFY INDEPENDENTLY

"Use a known Payroll contact channel for any business confirmation."

### KEEP CLASSIFICATION OPEN

"The message is still under assessment."

### CLOSE WITH A CLEAR NEXT STEP

"The response team will assess the report and provide instructions."

---

### No credentials

A relevant fact, not an all-clear.

### Thank you

Encourages reporting without promising immunity or outcomes.

### Urgent

A reason to verify, not a reason to bypass the reporting route.

# Choose the precise message

## **D** Check your understanding

Circle one best answer for each item. Use the stated purpose and case facts, not the option that merely sounds most polite.

### 1. Which opening is most useful?

- A** Tell me your password so I can check it.
- B** Thank you for reporting. What actions did you take, and when?
- C** Why would anyone fall for that?
- D** Nothing can happen if you entered no password.

### 2. Which status accurately reflects the facts?

- A** The link click proves all credentials were stolen.
- B** A suspicious-message report is under assessment; compromise is not established.
- C** Every payroll account has been breached.
- D** The email is safe because its display name says Payroll.

### 3. What should Ben use to submit the original?

- A** The approved reporting tool
- B** A message to every colleague
- C** A reply to the suspicious sender asking permission
- D** Repeated clicks to reproduce the issue on other devices

### 4. Which confirmation route avoids trusting the suspicious message?

- A** The phone number supplied only in that email
- B** The message's reply-to address without checking
- C** The linked page's assurance that it is genuine
- D** A previously verified Payroll contact channel

Answers and explanations: [page 97](#).

# Report the click, without guessing the consequence

## E Conversations / turns 1-10

Complete the numbered gaps. Use each bank entry once, without changing its form. Cover the answers at the end until you finish.

### WORD + PHRASE BANK

reporting tool / reporting promptly / compromise / reporting delay / display name / credential / out-of-band verification / intake / Message classification / interaction history

- 01 **Ben:** I clicked a payroll email and now I am worried it was suspicious. I reported it quickly, but I am concerned that I will be blamed.
- 02 **Leila:** Thank you for <sup>1</sup> \_\_\_\_\_. Accurate details help the response. Let us go through what you actually did, without guessing the consequence.
- 03 **Ben:** The email said I needed to confirm payroll information urgently. It showed Payroll as the sender name, so I assumed it came from our team.
- 04 **Leila:** That <sup>2</sup> \_\_\_\_\_ is useful context, but it does not verify the sender. Tell me the click time and what appeared next, without interacting with the message again.
- 05 **Ben:** I clicked at nine thirty-two UTC and reported it at nine thirty-six. A page opened. I did not type anything into it.
- 06 **Leila:** I will record the <sup>3</sup> \_\_\_\_\_. Did you enter credentials, open an attachment, or approve a sign-in prompt? Those are separate actions, and we need each one described accurately.
- 07 **Ben:** No credentials, no attachment, and no prompt approval. I can give you my password if that helps you check whether the account was affected.
- 08 **Leila:** Please do not share any <sup>4</sup> \_\_\_\_\_. We do not need your password in this conversation. We need the account identifier and factual actions through the approved response process.
- 09 **Ben:** I did not enter anything. Can I tell my manager the account is safe, or do you still need to check?
- 10 **Leila:** We have not established <sup>5</sup> \_\_\_\_\_, and I cannot give an all-clear from that fact alone. Your report narrows the assessment; it does not replace it.

# The conversation, continued

## E Conversations / turns 11-20

Continue with the word bank on page 64.

- 11 **Ben:** Understood. I still have the original email. Should I forward it to everyone in my department so they can recognize it and avoid clicking?
- 12 **Leila:** Use the approved <sup>6</sup> \_\_\_\_\_ for the original. Do not distribute the message more widely or interact further. The response team will assess it and coordinate any necessary communication.
- 13 **Ben:** I will use that route. The message also gives a phone number for Payroll. Should I call that number to ask whether they sent it?
- 14 **Leila:** Use <sup>7</sup> \_\_\_\_\_ through a Payroll channel you already know is genuine. A number supplied only in the suspicious message would rely on the same unverified source.
- 15 **Ben:** I can reach Payroll through our established internal contact. For the security report, I will keep the times and the original message available.
- 16 **Leila:** Good. The <sup>8</sup> \_\_\_\_\_ was four minutes in this case. Prompt reporting gives us useful information sooner, but we still need the assessment before describing the outcome.
- 17 **Ben:** I almost left out the click. I felt embarrassed and thought the fact that I had not entered a password was the important part.
- 18 **Leila:** Complete <sup>9</sup> \_\_\_\_\_ depends on those details. Please keep the account accurate. I can explain our response steps, but I should not make promises about decisions outside my role.
- 19 **Ben:** My manager can hear that I clicked, reported four minutes later, and did not enter credentials, open an attachment, or approve a prompt. Assessment is pending.
- 20 **Leila:** Exactly. <sup>10</sup> \_\_\_\_\_ is still open. Submit the original through the approved tool and follow the response team's instructions. Do not treat either embarrassment or reassurance as evidence.

07

### ANSWERS / EXPLANATIONS: PAGE 98

1. reporting promptly | 2. display name | 3. interaction history | 4. credential | 5. compromise | 6. reporting tool | 7. out-of-band verification | 8. reporting delay | 9. intake | 10. Message classification

# Report actions separately

## F Say it

An employee clicked a suspicious link at 14:10 UTC and reported it at 14:17. They report no credential entry. Message classification is pending. The approved tool is the required reporting route.

Complete the four gaps. Use each bank entry once.

07

### WORD + PHRASE BANK

pending / tool / credential / seven

Responder: "The reporting interval was <sup>1</sup> \_\_\_\_\_ minutes."

Employee: "I report no <sup>2</sup> \_\_\_\_\_ entry."

Responder: "Message classification is <sup>3</sup> \_\_\_\_\_."

Employee: "I will use the approved reporting <sup>4</sup> \_\_\_\_\_."

### ANSWERS / EXPLANATIONS: PAGE 98

1. seven | 2. credential | 3. pending | 4. tool

## Rehearse with a fixed script

1. Read turns 1-10. Use a calm tone and distinguish each reported action.
2. Switch roles for turns 11-20. Stress the trusted reporting route without promising an all-clear.
3. Check the transfer. Read the seven-minute interval and pending classification accurately.

### WORKING ALONE

Read both roles, pausing for two seconds when the speaker changes. Repeat with the bank covered, then check any missed expressions.

# A recovery shortfall needs a bounded decision

## **A** Read the situation

**Connect a measured security gap to a business consequence and a specific investment request without claiming guaranteed risk elimination.**

Security lead Imani briefs finance sponsor Victor on payroll resilience. A controlled recovery test took six hours against an approved four-hour recovery-time objective. It did not establish data loss, and no live incident is occurring. Payroll normally processes 200 scheduled records per hour. A four-hour interruption would defer 800 records at that assumed rate, not prove lost revenue. Proposal A requests \$30,000 for recovery automation and repeat testing. Proposal B requests \$20,000 for alert-dashboard improvements. The agreed priority is the evidenced payroll recovery shortfall; Victor must decide on A.

PEOPLE / Imani: Security lead | Victor: Finance sponsor

08

### **GIVE THE DECISION BEFORE THE TECHNICAL INVENTORY**

Executive listeners need the measured gap, its operational meaning, the proposed response, and the approval requested. Acknowledge alternatives fairly. Avoid converting a scenario into a forecast or a test result into a claim that a current attack is under way.

## Briefing checks

Circle one answer in each item. Use the briefing.

**1.** How far did the test exceed the recovery-time objective?

- |                              |                    |
|------------------------------|--------------------|
| <b>A</b> Four hours          | <b>B</b> Six hours |
| <b>C</b> Eight hundred hours | <b>D</b> Two hours |

**2.** What does the 800-record illustration mean?

- |                                                                    |                                           |
|--------------------------------------------------------------------|-------------------------------------------|
| <b>A</b> Deferred processing during four hours at the assumed rate | <b>B</b> Proven lost revenue of \$800     |
| <b>C</b> Confirmed destruction of 800 records                      | <b>D</b> A measured live-incident backlog |

**3.** What decision is requested?

- |                                                         |                                                              |
|---------------------------------------------------------|--------------------------------------------------------------|
| <b>A</b> Approval of an already completed live recovery | <b>B</b> \$30,000 for recovery automation and repeat testing |
| <b>C</b> \$20,000 for a payroll data-loss payment       | <b>D</b> A declaration that all cyber risk is eliminated     |

Answers and explanations: page 99.

# The vocabulary that does the work

## **B** Find the words / 1 of 2

Read the definitions and say the common word combinations aloud.

### **risk scenario**

A defined chain of conditions, event, and consequence.

**IN USE** describe a risk scenario

### **risk exposure**

The potential for loss or harm under stated conditions.

**IN USE** explain risk exposure

### **business consequence**

An effect on operations, obligations, or objectives.

**IN USE** connect to a business consequence

### **likelihood**

An assessment of how probable an event is.

**IN USE** qualify the likelihood estimate

### **impact estimate**

A bounded assessment of potential consequences.

**IN USE** state the impact estimate

### **uncertainty range**

An interval expressing limits on an estimate.

**IN USE** report an uncertainty range

### **recovery-time objective**

The target time for restoring a capability after disruption.

**IN USE** test the recovery-time objective

### **recovery-point objective**

The target limit on data loss measured in time.

**IN USE** distinguish the recovery-point objective

### **recovery test**

A controlled exercise of restoration capabilities.

**IN USE** run a recovery test

### **resilience**

Capacity to withstand disruption and restore required function.

**IN USE** improve operational resilience

### **processing backlog**

Work awaiting processing after capacity or availability is lost.

**IN USE** estimate the processing backlog

### **deferred processing**

Work delayed rather than necessarily lost.

**IN USE** quantify deferred processing

08

### **Precision check**

The test exceeded its four-hour objective by two hours, or 50% of that objective. A recovery-time objective concerns restoration time; a recovery-point objective concerns tolerable data loss in time. One does not establish the other.

# The vocabulary that does the work

## B Find the words / 2 of 2

Read the definitions and say the common word combinations aloud.

### service interruption

A period when a service is unavailable or impaired.

**IN USE** assess service interruption

### risk treatment

An action or decision to address a specified risk.

**IN USE** select risk treatment

### investment case

Reasons, costs, and expected outcomes supporting expenditure.

**IN USE** present an investment case

### decision request

A precise action sought from an authorized decision maker.

**IN USE** frame the decision request

### funding envelope

The defined amount available or requested for work.

**IN USE** specify the funding envelope

### implementation dependency

A prerequisite for carrying out a proposed change.

**IN USE** identify implementation dependencies

### success measure

A defined basis for judging a proposed outcome.

**IN USE** agree success measures

### assurance evidence

Support for confidence that an intended capability works.

**IN USE** collect assurance evidence

### risk appetite

The amount and type of risk an organization is willing to pursue or retain.

**IN USE** clarify risk appetite

### tolerance threshold

A defined boundary for acceptable deviation or exposure.

**IN USE** specify a tolerance threshold

### residual exposure

The relevant exposure remaining after a proposed measure.

**IN USE** disclose residual exposure

### review trigger

A condition requiring renewed assessment or decision.

**IN USE** define a review trigger

### Precision check

At 200 records per hour, four hours represents 800 scheduled records awaiting processing under the stated assumption. It does not establish lost revenue, permanent loss, or actual incident volume. The proposal still requires validation of its result.

# Phrases you can actually use

## **C** Notice the language / 1 of 2

### LEAD WITH THE GAP

"The test took six hours against a four-hour objective."

### SEPARATE TEST FROM INCIDENT

"This is a controlled test result, not a live outage."

### GIVE THE ASSUMPTION

"The illustration assumes 200 scheduled records per hour."

### REJECT FALSE LOSS LANGUAGE

"Deferred records are not automatically lost revenue."

### STATE THE DIFFERENCE

"That is a two-hour shortfall against the target."

### TRANSLATE THE OPERATION

"An interruption would delay payroll processing."

### USE THE RIGHT UNIT

"Four hours would defer 800 records at that rate."

### STATE THE REQUEST

"I am requesting \$30,000 for proposal A."

08

---

## Objective

A target, not a demonstrated current capability.

## Shortfall

Name the direction, amount, and comparison basis.

## Would

Marks a conditional consequence, not an observed event.

# Phrases you can actually use

## **C** Notice the language / 2 of 2

### NAME THE WORK

"The scope is recovery automation and repeat testing."

### REPRESENT THE ALTERNATIVE

"B improves alert dashboards but does not directly address this test result."

### DEFINE SUCCESS

"Repeat the agreed test against the four-hour objective."

### KEEP AUTHORITY EXPLICIT

"Funding remains subject to your decision."

### CONNECT THE PRIORITY

"A directly addresses the measured recovery shortfall."

### AVOID A GUARANTEE

"The proposal needs evidence that recovery performance improves."

### DISCLOSE REMAINING RISK

"This does not remove every security exposure."

### CLOSE THE BRIEFING

"Approve or decline A on this scope, with results reviewed after testing."

08

---

## Records

Not interchangeable with customers, dollars, or lost transactions.

## Improvement

Requires evidence after the proposed work.

## Approve

Authorizes the stated scope, not every future security initiative.

# Choose the precise message

## **D** Check your understanding

Circle one best answer for each item. Use the stated purpose and case facts, not the option that merely sounds most polite.

### 1. Which opening is most decision-ready?

- A** A six-hour recovery test missed the four-hour objective; I request \$30,000 to automate and retest.
- B** We have many tools and technical concerns.
- C** A live attack has destroyed all payroll data.
- D** The dashboard has attractive features, so all risk is solved.

### 2. Which statement about data loss is supported?

- A** Four-hour RTO guarantees zero data loss.
- B** Eight hundred deferred records were permanently deleted.
- C** The supplied test does not establish data loss.
- D** Six hours of recovery proves six hours of data loss.

### 3. Why does A rank ahead under the stated priority?

- A** B can never have any security value.
- B** The test proves every dashboard is useless.
- C** It directly addresses the evidenced payroll recovery shortfall.
- D** It costs more, so it must be better.

### 4. What should follow the proposed automation?

- A** Replace the target with six hours without a decision.
- B** Claim all attacks are now impossible.
- C** Repeat the agreed recovery test and assess evidence against the objective.
- D** Declare success on purchase alone.

Answers and explanations: [page 99](#).

# A recovery shortfall needs a bounded decision

## E Conversations / turns 1-10

Complete the numbered gaps. Use each bank entry once, without changing its form. Cover the answers at the end until you finish.

### WORD + PHRASE BANK

service interruption / assurance evidence / recovery test / decision request / deferred processing / funding envelope / risk treatment / success measure / Residual exposure / recovery-time objective

08

- 01 **Victor:** The proposal lists several technical weaknesses. I need to know what decision you want and why this work comes before the dashboard upgrade.
- 02 **Imani:** Our <sup>1</sup> \_\_\_\_\_ took six hours against an approved four-hour target. I am requesting thirty thousand dollars for recovery automation and repeat testing to address that measured gap.
- 03 **Victor:** So we missed the target by two hours. Is that a statement about how long payroll data was lost, or how long restoration took?
- 04 **Imani:** It concerns the <sup>2</sup> \_\_\_\_\_. We measured restoration time. The test does not establish data loss, and I should not describe the six-hour result as six hours of lost information.
- 05 **Victor:** Then explain the business consequence in operational terms. I want the committee to understand the exposure without hearing an unsupported claim about a current attack.
- 06 **Imani:** A <sup>3</sup> \_\_\_\_\_ would delay payroll processing. At the stated rate of two hundred scheduled records per hour, a four-hour interruption would defer eight hundred records.
- 07 **Victor:** That is a useful scale. But eight hundred records does not mean eight hundred customers permanently lost, or eight hundred dollars of lost revenue.
- 08 **Imani:** Correct. This is <sup>4</sup> \_\_\_\_\_, not a calculated revenue loss. The rate is an assumption for the illustration, and there is no live incident in this briefing.
- 09 **Victor:** What exactly does the thirty thousand fund? I do not want an approval interpreted as a general authorization for unrelated tooling later in the year.
- 10 **Imani:** The <sup>5</sup> \_\_\_\_\_ covers proposal A: recovery automation and repeat testing. Any additional scope or funding would need its own decision rather than being implied by this approval.

# The conversation, continued

## E Conversations / turns 11-20

Continue with the word bank on page 73.

- 11 **Victor:** The dashboard is ten thousand dollars cheaper. Why not buy that first? Tell me how each option addresses the gap we actually measured.
- 12 **Imani:** It could improve alert visibility, but our agreed <sup>6</sup> \_\_\_\_\_ priority is the evidenced payroll recovery shortfall. A is directly aimed at that gap; B does not directly address this test result.
- 13 **Victor:** How will we know whether the automation works? A purchase receipt will show spending, but it will not show that recovery has become faster.
- 14 **Imani:** The <sup>7</sup> \_\_\_\_\_ is performance in the agreed repeat test against the four-hour objective. We need that evidence before claiming that the restoration capability meets the target.
- 15 **Victor:** If the repeat test meets four hours, what risk remains? I need that limitation in the committee note, not just the improvement headline.
- 16 **Imani:** No. <sup>8</sup> \_\_\_\_\_ remains, and this work addresses one defined capability. Faster recovery does not establish prevention of every incident or eliminate every consequence of disruption.
- 17 **Victor:** That distinction belongs in the committee note. We have a measured gap, a conditional operational illustration, a bounded proposal, and a validation requirement.
- 18 **Imani:** I will include the <sup>9</sup> \_\_\_\_\_ expected from the repeat test and identify any implementation dependencies. The recommendation should show what must be demonstrated, not just what we hope to buy.
- 19 **Victor:** I can now evaluate the request against the agreed priority. Please keep the approval status open until I record the decision on that specific scope.
- 20 **Imani:** Understood. The <sup>10</sup> \_\_\_\_\_ is approval of A for thirty thousand dollars, with results reviewed after testing. I will not describe the funding or the improvement as already secured.

08

### ANSWERS / EXPLANATIONS: PAGE 100

1. recovery test | 2. recovery-time objective | 3. service interruption | 4. deferred processing | 5. funding envelope | 6. risk treatment | 7. success measure | 8. Residual exposure | 9. assurance evidence | 10. decision request

# Translate the number without changing its meaning

## F Say it

A recovery test takes five hours against a three-hour objective. At an assumed 100 scheduled records per hour, a three-hour interruption would defer work. No data loss or live incident is established.

Complete the four gaps. Use each bank entry once.

08

### WORD + PHRASE BANK

two / unestablished / 100 / 300

Security: "The test exceeded the objective by <sup>1</sup> \_\_\_\_\_ hours."

Sponsor: "The illustration uses <sup>2</sup> \_\_\_\_\_ records per hour."

Security: "Three hours would defer <sup>3</sup> \_\_\_\_\_ records."

Sponsor: "Data loss remains <sup>4</sup> \_\_\_\_\_."

### ANSWERS / EXPLANATIONS: PAGE 100

1. two | 2. 100 | 3. 300 | 4. unestablished

## Rehearse with a fixed script

1. Read turns 1-10. Stress restoration time, the assumed rate, and deferred records.
2. Switch roles for turns 11-20. Contrast requested funding with demonstrated improvement.
3. Check the transfer. Read the two-hour excess and 300-record illustration with their units.

### WORKING ALONE

Read both roles, pausing for two seconds when the speaker changes. Repeat with the bank covered, then check any missed expressions.

# Deleting the post does not revoke the credential

## E More workplace conversations / 1-10

**Coordinate credential containment, replacement, and evidence without sharing the secret again.**

An engineer posted a live service token in a public support snippet, then deleted the post. The token is still active. The response lead can authorize immediate revocation under the local process; the service owner must coordinate replacement. Misuse has not been established.

PEOPLE / Sofia: Service engineer | Malik: Response lead

Use each bank entry once, without changing its form. Answers follow turn 20.

09

### WORD + PHRASE BANK

audit log / blast radius / rotation / credential identifier / secret store / revocation

- 01 **Sofia:** I deleted the support post as soon as I noticed the token. The page is gone. Can we close the report?
- 02 **Malik:** No. Removing the post does not perform <sup>1</sup> \_\_\_\_\_. The token is still active, and someone may already have copied it.
- 03 **Sofia:** It belongs to the nightly integration. I can identify the credential record without pasting its value into this chat.
- 04 **Malik:** Use that <sup>2</sup> \_\_\_\_\_. I am authorizing revocation through our response process now. Notify the owner that dependent work may be interrupted.
- 05 **Sofia:** I have sent the identifier through the restricted case channel. The owner is joining, and the revocation action has been submitted.
- 06 **Malik:** Record when it is actually confirmed. Requested and disabled are different states; we should not claim the token is unusable until the result is verified.
- 07 **Sofia:** Revocation is now confirmed. The owner says a replacement is needed before the next run. Can we put the new value in the configuration ticket?
- 08 **Malik:** No. Use the approved <sup>3</sup> \_\_\_\_\_. The ticket can reference the controlled record and owner without containing the replacement secret.
- 09 **Sofia:** The integration still has to retrieve it. I will coordinate that change with the owner and verify the approved consumer can authenticate.
- 10 **Malik:** Also confirm that the revoked credential is rejected through the authorized verification process. A successful new connection alone does not establish that the old token stopped working.

# The conversation, continued

## E More workplace conversations / 11-20

Continue with the word bank on page 76.

- 11 **Sofia:** That gives us two separate checks. Would this complete the credential rotation, even though the investigation stays open?
- 12 **Malik:** The <sup>4</sup> \_\_\_\_\_ can be completed and recorded separately. Do not use that completion to claim there was no earlier unauthorized activity.
- 13 **Sofia:** The owner found another scheduled job using the same credential. It was missing from our first dependency list.
- 14 **Malik:** Add it and assess the interruption. That also changes the <sup>5</sup> \_\_\_\_\_ we understood, so update the impact note rather than leave the first description unqualified.
- 15 **Sofia:** Should the replacement keep all the old permissions? Some were added for a one-off task months ago.
- 16 **Malik:** Review the required permissions with the owner. Do not carry unnecessary access forward merely because it was present before the exposure.
- 17 **Sofia:** The provider records are available for part of the exposure period, but an earlier interval is missing. I found no unexplained use in the available records.
- 18 **Malik:** Keep that limit beside the <sup>6</sup> \_\_\_\_\_ result. No unexplained use found in those records is narrower than proof that nobody used the token.
- 19 **Sofia:** The update will separate post removal, confirmed revocation, replacement work, affected jobs, and the investigation gap. I will not include either secret value.
- 20 **Malik:** Good. Preserve the relevant evidence through the approved process and keep the case open for the remaining assessment, even when the integration is running again.

09

### ANSWERS / EXPLANATIONS: PAGE 101

1. revocation | 2. credential identifier | 3. secret store | 4. rotation | 5. blast radius | 6. audit log

# A working replacement is treated as proof of containment

## **F** Say it in a new situation

A replacement token works for the approved job, but nobody has verified that the exposed token is disabled. General tickets must not contain secret values.

Complete the four gaps. Use each bank entry once.

### WORD + PHRASE BANK

value / operation / revocation / result

09

Engineer: The successful job confirms the new token works, not the old token's  
1 \_\_\_\_\_.

Lead: Verify rejection through the authorized process and record the  
2 \_\_\_\_\_.

Engineer: The ticket will refer to the controlled record, not include the secret  
3 \_\_\_\_\_.

Lead: Keep the investigation separate from restored service 4 \_\_\_\_\_.

### ANSWERS / EXPLANATIONS: PAGE 101

1. revocation | 2. result | 3. value | 4. operation

## Read, switch, repeat

1. Check the four answers and read the complete exchange aloud.
2. Switch roles. Read it again with the word bank covered.
3. Return to the extended conversation. Read turns 1-10, then switch roles for turns 11-20. Use the corrected expressions.

### SOLO PRACTICE

Read both roles. Pause briefly at each change of speaker. Repeat any line that needed an answer check.

# A linked service is not automatically in the test scope

## **E** More workplace conversations / 1-10

### Clarify testing permission, boundaries, and stop conditions before an assessment begins.

An authorized assessment covers fictional staging service Lab-A from 22:00 to 23:00 UTC using listed methods. It excludes production and third-party systems. Lab-A redirects to a supplier login. The consultant asks whether that login is included; no permission for it is documented.

PEOPLE / Kenji: Assessment consultant | Amara: Service owner

Use each bank entry once, without changing its form. Answers follow turn 20.

10

#### WORD + PHRASE BANK

test window / point of contact / authorization / stop condition / rules of engagement / scope

- 01 **Kenji:** Before we start, Lab-A redirects to the supplier login. Is that service covered by the authorization, or do we stop at the redirect?
- 02 **Amara:** It is outside the listed <sup>1</sup> \_\_\_\_\_. Our authorization covers Lab-A, not the supplier environment. Do not test the linked service on that basis.
- 03 **Kenji:** Understood. I will record the dependency without sending assessment traffic to it. The product team thought a link made it part of our application.
- 04 **Amara:** The <sup>2</sup> \_\_\_\_\_ need to make that boundary clear. I can clarify our requirements, but I cannot grant permission on the supplier's behalf.
- 05 **Kenji:** We also have a list of allowed methods. A stakeholder asked for an availability stress test, which is not on that list.
- 06 **Amara:** That request does not change the agreement. Route any proposed addition through the authorization process and leave it out of the current assessment.
- 07 **Kenji:** The window says twenty-two hundred to twenty-three hundred UTC. My local calendar converted it differently because of the time zone setting.
- 08 **Amara:** Use the stated <sup>3</sup> \_\_\_\_\_ and correct the invitation. Confirm both endpoints with the team before starting, rather than rely on a local display.
- 09 **Kenji:** Who can we reach during the window if an unexpected service issue appears? I have your daytime office number only.
- 10 **Amara:** I will confirm the on-duty contact and escalation route in the approved document. Testing should not begin with an unresolved response contact.

# The conversation, continued

## **E** More workplace conversations / 11-20

Continue with the word bank on page 79.

- 11 **Kenji:** If we unexpectedly encounter real customer information in staging, should we collect a sample to prove the finding?
- 12 **Amara:** Follow the agreed <sup>4</sup> \_\_\_\_\_. Pause the affected activity and notify the designated contact. Do not expand access or collect additional customer content to make a stronger demonstration.
- 13 **Kenji:** We can document the minimal observation through the restricted reporting route and let the response owner direct the handling.
- 14 **Amara:** Yes. Preserve necessary evidence under the agreed rules without turning an unexpected exposure into unnecessary copying or wider distribution.
- 15 **Kenji:** And if the system becomes unstable during the approved work, we pause and contact the same on-duty person rather than continue to complete the checklist?
- 16 **Amara:** Correct. The <sup>5</sup> \_\_\_\_\_ must be reachable. Completing the planned steps does not override the agreed interruption procedure.
- 17 **Kenji:** I will send the clarified boundary, UTC window, methods, contacts, and stop conditions for confirmation. We are not starting the new request tonight.
- 18 **Amara:** Any expanded activity needs written <sup>6</sup> \_\_\_\_\_ before it happens. That includes resolving permission for any third-party environment involved.
- 19 **Kenji:** The report will separate tested areas from excluded and untested dependencies. I will not describe a clean Lab-A result as a test of the supplier login.
- 20 **Amara:** Good. Keep the limitations visible so the assessment answers what was actually examined, not what someone assumed was included.

10

### ANSWERS / EXPLANATIONS: PAGE 102

1. scope | 2. rules of engagement | 3. test window | 4. stop condition | 5. point of contact | 6. authorization

# The approved window is mistaken for unlimited permission

## **F** Say it in a new situation

A consultant has permission to assess a named staging system from 20:00 to 21:00 UTC using listed methods. Production and stress testing are excluded.

Complete the four gaps. Use each bank entry once.

### WORD + PHRASE BANK

authorization / window / methods / environment

10

Owner: Approval is limited to the named staging <sup>1</sup> \_\_\_\_\_.

Consultant: I will work only within the stated UTC <sup>2</sup> \_\_\_\_\_.

Owner: Keep the activity within the listed <sup>3</sup> \_\_\_\_\_.

Consultant: Any expansion needs separate <sup>4</sup> \_\_\_\_\_.

### ANSWERS / EXPLANATIONS: PAGE 102

1. environment | 2. window | 3. methods | 4. authorization

## Read, switch, repeat

1. Check the four answers and read the complete exchange aloud.
2. Switch roles. Read it again with the word bank covered.
3. Return to the extended conversation. Read turns 1-10, then switch roles for turns 11-20. Use the corrected expressions.

### SOLO PRACTICE

Read both roles. Pause briefly at each change of speaker. Repeat any line that needed an answer check.

# The supplier has a report, but what does it cover?

## **E** More workplace conversations / 1-10

**Read assurance scope critically without treating a report as a blanket security guarantee.**

A fictional supplier provides a SOC 2 Type 2 report covering its Core service from January 1 to June 30. An August add-on is outside the described system. The report lists customer-side access reviews and excludes a hosting provider under the carve-out method. Purchasing wants immediate approval.

PEOPLE / Lucia: Procurement manager | Dev: Third-party assurance analyst

Use each bank entry once, without changing its form. Answers follow turn 20.

### WORD + PHRASE BANK

complementary user entity controls / bridge letter / system boundary / test exception / carve-out method / reporting period

11

- 01 **Lucia:** The supplier sent its SOC 2 report. Can I mark the security review complete and issue the order for Core plus the new add-on?
- 02 **Dev:** First check the <sup>1</sup> \_\_\_\_\_. This Type 2 report covers January through June. It is useful evidence, not a guarantee about every service at every later date.
- 03 **Lucia:** The order includes an add-on introduced in August. The cover has the supplier name, but I do not see that product in the system description.
- 04 **Dev:** Then the <sup>2</sup> \_\_\_\_\_ matters. The report covers Core. We need evidence for the add-on rather than assume the company name extends coverage to it.
- 05 **Lucia:** There is a section asking customers to review their own users' access. I thought the supplier's controls covered all access administration.
- 06 **Dev:** Those are <sup>3</sup> \_\_\_\_\_. We need an owner for the applicable customer-side responsibilities, not just a copy of the supplier's report.
- 07 **Lucia:** I will route that to our service owner. Does the report also examine the hosting provider's controls? Its name appears in the description.
- 08 **Dev:** Not in the way you are assuming. The report uses the <sup>4</sup> \_\_\_\_\_ for that provider. We must understand the dependency and the separate assurance needed.
- 09 **Lucia:** So excluded from this examination does not mean the hosting controls failed. It means this report does not supply that examination evidence.
- 10 **Dev:** Correct. Do not turn an evidence boundary into an unsupported failure claim. Equally, do not mark the dependency assessed merely because the provider is named.

# The conversation, continued

## E More workplace conversations / 11-20

Continue with the word bank on page 82.

- 11 **Lucia:** One test table records a late access review. Should I describe that as proof the supplier suffered a breach?
- 12 **Dev:** No. A <sup>5</sup> \_\_\_\_\_ needs context: the control, affected scope, test result, response, and implications for us. Read it alongside the auditor's opinion.
- 13 **Lucia:** And an exception is not automatically the same as a qualified opinion? I should not substitute my own label for what the auditor actually concluded.
- 14 **Dev:** Exactly. Record the actual opinion and findings, then assess their relevance to our intended service and information. A headline badge cannot do that work.
- 15 **Lucia:** The supplier offers a letter about changes since June. Can that extend the auditor's examination to the present?
- 16 **Dev:** A management <sup>6</sup> \_\_\_\_\_ is additional information, not a new independent examination. Read who made the statement and what it actually covers.
- 17 **Lucia:** I will request the latest relevant assurance and specific information on the August add-on. That is narrower than asking them to repeat every document they have.
- 18 **Dev:** Good. Also identify our access-review owner and the hosting dependency. Those are different open items, so keep each request connected to its purpose.
- 19 **Lucia:** The purchasing status will say report received, review in progress, Core scope identified, and add-on evidence outstanding. No final security approval yet.
- 20 **Dev:** That accurately separates receiving a document from reaching a risk decision. We can acknowledge the useful evidence without extending its conclusions beyond their scope.

11

### ANSWERS / EXPLANATIONS: PAGE 103

1. reporting period | 2. system boundary | 3. complementary user entity controls | 4. carve-out method | 5. test exception | 6. bridge letter

# A supplier name is mistaken for coverage of every product

## F Say it in a new situation

A report describes service Atlas for January-June. The proposed purchase also includes Nova, introduced in August and absent from the system description.

Complete the four gaps. Use each bank entry once.

### WORD + PHRASE BANK

Atlas / approval / Nova / June

Buyer: The described service is <sup>1</sup> \_\_\_\_\_, not every product sold by the supplier.

Reviewer: The examination ends in <sup>2</sup> \_\_\_\_\_.

Buyer: We still need evidence relevant to <sup>3</sup> \_\_\_\_\_.

Reviewer: Report receipt is not the same as final risk <sup>4</sup> \_\_\_\_\_.

11

### ANSWERS / EXPLANATIONS: PAGE 103

1. Atlas | 2. June | 3. Nova | 4. approval

## Read, switch, repeat

1. Check the four answers and read the complete exchange aloud.
2. Switch roles. Read it again with the word bank covered.
3. Return to the extended conversation. Read turns 1-10, then switch roles for turns 11-20. Use the corrected expressions.

### SOLO PRACTICE

Read both roles. Pause briefly at each change of speaker. Repeat any line that needed an answer check.

# 01 Briefing and language checks

## Security Triage and Alert Investigation

### A Briefing checks / page 4

1. What does the identity log establish?

**C. A successful privileged-account sign-in at 02:14 UTC**

The log establishes the sign-in event, not the identity or permission behind it.

2. What is missing from 02:10-02:20 UTC?

**A. Application logs**

The briefing identifies an application-log gap during the relevant period.

3. What does the local process require now?

**B. Escalation to Luis while correlation continues**

The stated process requires prompt escalation without first asserting a confirmed cause.

### D Language checks / page 9

1. Which handoff best fits S14?

**D. Successful privileged sign-in; authorization unverified; application-log gap; escalated for investigation.**

The correct summary preserves all four facts. The alternatives invent authorization, erase the visibility gap, or delay the required escalation.

2. Which record would help test the maintenance explanation?

**A. A ticket matching this host, account, and authorized task**

A relevant authorization record must connect to this event rather than merely exist.

3. Why is the log gap relevant?

**D. It limits what the team can exclude about application activity.**

Missing visibility limits negative conclusions without proving why the records are absent.

4. Which wording avoids premature blame?

**A. The account was used; the operator is not yet verified.**

Account activity does not by itself identify the person or their intent.

# 01 Conversation answers

## Security Triage and Alert Investigation

### E Dialogue gaps

Pages 10-11

- 1. event.** Turn 2. The event is the recorded sign-in, distinct from the conclusion that it was malicious.
- 2. hypothesis.** Turn 4. Maintenance is a possible explanation because the timing overlaps, but the relevant match is unverified.
- 3. triage.** Turn 6. Triage is the initial assessment and handling process that continues while the owner response is pending.
- 4. visibility gap.** Turn 8. The missing application logs create a visibility gap that restricts the conclusions available to investigators.
- 5. anomaly.** Turn 10. An unfamiliar address departs from the expected pattern but does not establish malicious ownership or intent.
- 6. authentication.** Turn 12. Authentication concerns the identity check reflected in the successful sign-in, not permission for every subsequent action.
- 7. authorization.** Turn 14. Authorization is permission for the specific action, which requires more than a ticket with overlapping times.
- 8. case record.** Turn 16. The case record preserves the evidence, unanswered questions, and actions for the next analyst.
- 9. confidence level.** Turn 18. The confidence level qualifies the current interpretation and should change with evidence rather than with repeated assertion.
- 10. correlation.** Turn 20. Correlation connects the identity event to relevant ticket and host records to test the competing explanations.

### F Transfer conversation

Page 12

#### 1. UTC

Analyst: "The event time is 05:20 UTC."

The briefing explicitly gives the event time in Coordinated Universal Time.

#### 2. unverified

Lead: "The account match remains unverified."

The overlapping maintenance period does not establish the relevant account match.

#### 3. unavailable

Analyst: "Application logs are unavailable."

The supplied absence of application logs limits the investigation evidence.

#### 4. received

Lead: "The escalation has been received."

The briefing says the shift lead has already received the escalation.

# 02 Briefing and language checks

## Incident Response and Containment

### A Briefing checks / page 13

1. When was isolation completion verified?

**B. 09:22 UTC**

The case distinguishes the first report, authorization, completion, and next update.

2. What is the confirmed operational impact?

**D. Billing jobs are paused.**

The supplied service effect is paused billing jobs, not wider damage.

3. What does 09:45 represent?

**C. The next update time**

The briefing expressly makes 09:45 a communication commitment, not a recovery promise.

### D Language checks / page 18

1. Which timeline is accurate?

**C. Report 09:10; isolation authorized 09:18; completion verified 09:22.**

The correct timeline preserves the distinct states and supplied timestamps.

2. Which reply addresses pressure to restore now?

**C. Billing is paused; restoration still requires the specified response and service-owner process.**

Operational urgency does not remove the restoration conditions stated in the case.

3. Which statement about data access is justified?

**A. Unauthorized data access has not been confirmed.**

The case leaves data access unresolved rather than establishing either extreme.

4. What belongs in the handover?

**B. Actions, timestamps, impact, open questions, and responsible roles**

These items preserve usable continuity without inventing conclusions or authority.

# 02 Conversation answers

## Incident Response and Containment

### E Dialogue gaps

Pages 19-20

**1. containment.** Turn 2. Containment aims to limit impact; it does not establish that investigation, eradication, or recovery is complete.

**2. action log.** Turn 4. The action log records the report, authorization, and verified execution as separate events.

**3. business impact.** Turn 6. The confirmed business impact is paused billing jobs, not an assumed broader outage or data loss.

**4. Evidence preservation.** Turn 8. Evidence preservation protects relevant information from loss or alteration while response decisions are coordinated.

**5. decision authority.** Turn 10. The local process assigns restoration decisions to the response lead and service owner, not any individual requesting speed.

**6. Eradication.** Turn 12. Eradication concerns removing the incident cause or persistence as applicable and is distinct from isolating a host.

**7. incident scope.** Turn 14. Incident scope covers the systems and effects under investigation; it remains incomplete in this case.

**8. status update.** Turn 16. The agreed status update commits the team to communicate at 09:45 without promising restoration by then.

**9. handover.** Turn 18. The handover transfers the current evidence, decisions, impact, and outstanding work to the incoming team.

**10. Recovery.** Turn 20. Recovery is the controlled restoration of affected capabilities and is not established merely by isolation.

### F Transfer conversation

Page 21

#### 1. 11:05

Coordinator: "Isolation was authorized at 11:05 UTC."

The briefing assigns 11:05 to authorization rather than to completion.

#### 2. 11:09

Owner: "Completion was verified at 11:09 UTC."

The verified completion occurred four minutes after the recorded authorization.

#### 3. 11:30

Coordinator: "Our next update is at 11:30 UTC."

The supplied time is a communication commitment, not automatic recovery permission.

#### 4. unauthorized

Owner: "Recovery remains unauthorized."

The briefing explicitly states that recovery has not been authorized.

# 03 Briefing and language checks

## Vulnerability Management

03

### A Briefing checks / page 22

1. Which finding comes first under the stated tie-break rule?

**A. A, the exposed production gateway flaw**

The stated rule favors A because external exposure and demonstrated exploitation are supplied.

2. What does the threat bulletin establish?

**D. The flaw has been exploited elsewhere.**

Exploitation elsewhere is relevant evidence but does not prove a local incident.

3. What remains required after selecting A first?

**B. Testing, change approval, and verification**

Prioritization orders the work without completing the required change and verification steps.

### D Language checks / page 27

1. Which explanation is strongest for A first?

**A. Equal scores; A adds external exposure and validated exploitation evidence under the agreed rule.**

The correct explanation uses the actual differentiators without inventing a score or incident.

2. Which statement about B is accurate?

**D. It is lower in this ordering but still requires handling.**

The tie-break changes priority, not the existence or eventual handling of B.

3. What distinguishes a patch from a mitigation?

**A. A patch changes software; another control may reduce exposure without correcting that software.**

The distinction concerns how the weakness or its exposure is addressed.

4. Which closure message is supported before any deployment?

**B. A is prioritized; deployment and verification are still pending.**

Available patches and selected priorities do not establish completed remediation.

# 03 Conversation answers

## Vulnerability Management

03

### E Dialogue gaps

Pages 28-29

- 1. base score.** Turn 2. The base score reflects intrinsic severity characteristics and does not include every relevant local risk factor.
- 2. internet-facing.** Turn 4. Internet-facing identifies A's external exposure, which differentiates it from the isolated test system.
- 3. exploitation in the wild.** Turn 6. Real-world exploitation elsewhere supports prioritization but does not by itself establish local compromise.
- 4. remediation.** Turn 8. Remediation is the corrective work still required for both findings, even though A comes first.
- 5. change approval.** Turn 10. Change approval authorizes the defined operational change; a security priority does not automatically supply that permission.
- 6. regression test.** Turn 12. A regression test checks that applying the change has not broken existing behavior required by the service.
- 7. mitigation.** Turn 14. A mitigation reduces a defined exposure or impact and need not remove the underlying software weakness.
- 8. risk acceptance.** Turn 16. Risk acceptance is an authorized decision concerning a specified retained risk, not an informal label that erases the weakness.
- 9. closure evidence.** Turn 18. Closure evidence demonstrates that the required completion conditions were actually met after the change.
- 10. asset criticality.** Turn 20. Asset criticality adds the importance of the production gateway to the context of the prioritization discussion.

### F Transfer conversation

Page 30

#### 1. X

Analyst: "The first priority is X."

The supplied tie-break rule favors the exposed flaw with demonstrated exploitation.

#### 2. equal

Owner: "The base scores are equal."

The case explicitly makes the base severity scores the same.

#### 3. elsewhere

Analyst: "Exploitation is verified elsewhere."

The supplied evidence describes exploitation elsewhere, not a confirmed local incident.

#### 4. pending

Owner: "Deployment is still pending."

The briefing says deployment has not started despite patch availability.

# 04 Briefing and language checks

## Identity, Access, and Least Privilege

04

### A Briefing checks / page 31

1. What does the diagnostic task require?

**A. Read access to sanitized logs for two hours**

The briefing supplies a narrow read-only task with a defined two-hour duration.

2. Which local requirement is explicit?

**A. Named identities with multifactor authentication, approval, and expiry**

These four conditions are stated in the fictional local access policy.

3. What is the current approval status?

**A. Not granted**

The briefing explicitly says no approval has yet been granted.

### D Language checks / page 36

1. Which proposal best matches the supplied task and policy?

**A. Named read-only log access for two hours, with MFA and owner approval**

The correct proposal preserves individual identity, task-limited permission, authentication, approval, and duration. Each alternative changes one required boundary.

2. Why does MFA not settle the request?

**A. It strengthens identity verification but does not justify unnecessary permissions.**

Authentication strength and permission scope address different questions in access decisions.

3. What should happen if a write task emerges?

**A. Submit the additional need for a separate assessment.**

The original facts justify only reading, and the briefing requires a separate request for writes.

4. Which explanation avoids blaming the vendor?

**A. The task requires log reading, so we are proposing only that access.**

The task-based explanation states a legitimate boundary without making a personal accusation.

# 04 Conversation answers

## Identity, Access, and Least Privilege

### E Dialogue gaps

Pages 37-38

**1. least privilege.** Turn 2. Least privilege ties the permissions to the actual authorized task rather than to the broadest convenient account.

**2. read-only access.** Turn 4. Read-only access matches inspection of the supplied diagnostic logs without adding unsupported write or administrative rights.

**3. named account.** Turn 6. A named account associates access with an identified technician, as required by the stated local policy.

**4. multifactor authentication.** Turn 8. Multifactor authentication is the explicit local sign-in condition and is separate from the task's permission scope.

**5. time-bound access.** Turn 10. Time-bound access records a limited period of need instead of granting ongoing privilege for a short task.

**6. Provisioning.** Turn 12. Provisioning enables the access, but the case still requires owner approval before that approved arrangement can be implemented.

**7. entitlement.** Turn 14. An entitlement is a particular permission; adding write authority changes the access requested and needs reassessment.

**8. Accountability.** Turn 16. Accountability preserves a connection between actions and individual identities rather than making an accusation about intentions.

**9. expiry.** Turn 18. Expiry specifies when the permission ends, making the temporary access boundary concrete and reviewable.

**10. deprovisioning.** Turn 20. Deprovisioning removes or disables access after the approved need ends rather than leaving an unused permission active.

### F Transfer conversation

Page 39

#### 1. read-only

Coordinator: "The requested permission is read-only."

Viewing the supplied logs does not require writing or administrative permissions.

#### 2. three

Reviewer: "The requested duration is three hours."

The briefing explicitly limits the diagnostic task to three hours.

#### 3. named

Coordinator: "The identity must be named."

The stated local policy requires an individually identified account.

#### 4. pending

Reviewer: "Owner approval remains pending."

The supplied facts say approval has not yet been granted.

04

# 05 Briefing and language checks

## Threat Modeling and Secure Design

### A Briefing checks / page 40

05

1. What does the supplied draft already check?

**D. The user at sign-in**

The draft describes a sign-in check but lacks the separate per-document authorization decision.

2. What security requirement is supplied?

**D. Customers may see only their own organization-owned documents.**

The briefing explicitly defines the organization-level document-access boundary.

3. What is not established?

**A. A confirmed breach or implemented-system test result**

The discussion concerns the draft design, not an already proven live exploit.

### D Language checks / page 45

1. Which requirement closes the identified design gap?

**A. Enforce server-side permission for each requested document.**

The missing decision concerns permission for the requested object, not only identity or interface presentation.

2. Which pair best tests the stated boundary?

**B. An authorized same-tenant request and a denied cross-tenant request using controlled data**

The pair checks both intended access and the protected boundary within authorized test scope.

3. Which statement overclaims the review evidence?

**A. A customer breach has definitely occurred.**

The briefing explicitly supplies no confirmed breach or implemented-system test result.

4. Why is a browser-supplied ID not enough?

**C. A value naming an object does not establish permission to access it.**

Identifying a document and authorizing access to it are separate functions.

# 05 Conversation answers

## Threat Modeling and Secure Design

### E Dialogue gaps

Pages 46-47

- 1. data flow.** Turn 2. The data flow shows how the identifier moves from the browser through the service to storage.
- 2. authorization check.** Turn 4. The authorization check decides permission for the requested document, distinct from verifying identity at sign-in.
- 3. abuse case.** Turn 6. The abuse case describes a signed-in user attempting access outside the intended document boundary.
- 4. trust boundary.** Turn 8. The trust boundary separates client-controlled input from the service's responsibility to enforce access decisions.
- 5. object-level authorization.** Turn 10. Object-level authorization applies the permission rule to each specific requested document rather than to sign-in alone.
- 6. security requirement.** Turn 12. A security requirement states a checkable protected outcome while preserving the intended authorized behavior.
- 7. tenant isolation.** Turn 14. Tenant isolation concerns preventing unauthorized access between customer organizations sharing the service.
- 8. threat model.** Turn 16. The threat model records the design-level threat and response without converting an untested design gap into a confirmed breach.
- 9. server-side enforcement.** Turn 18. Server-side enforcement places the permission decision in the controlled service rather than relying on browser behavior.
- 10. information disclosure.** Turn 20. Information disclosure is unauthorized exposure of document content, the specific harm addressed by this access requirement.

### F Transfer conversation

Page 48

#### 1. identity

Architect: "The existing check establishes identity."

The supplied design checks the signed-in identity rather than invoice permission.

#### 2. authorization

Security: "Each invoice also needs an authorization check."

Authorization determines whether the user may access the particular requested invoice.

#### 3. server

Architect: "Enforcement belongs on the server."

The proposed control is enforced by the service, not by client convention.

#### 4. pending

Security: "Implementation validation remains pending."

The briefing says no implementation test has yet been performed.

05

# 06 Briefing and language checks

## Governance, Risk, and Compliance

### A Briefing checks / page 49

1. How many sampled records prove timely removal?

**C. Three of five**

Three records contain evidence of removal within the stated twenty-four-hour limit.

2. What do the other two records lack?

**D. Removal timestamps**

The briefing identifies missing timestamps rather than confirmed late removals.

3. Can the finding close under the supplied criteria?

**B. No; evidence and owner review are incomplete.**

The stated closure conditions require all five cases to be evidenced and owner review recorded.

### D Language checks / page 54

1. Which summary is accurate?

**B. Three timely removals are evidenced; two are unverified; owner review is missing.**

The correct summary keeps documented timeliness, missing evidence, and missing review separate.

2. What is 3 divided by 5 in this case?

**D. 60% of the sample with documented timely removal**

The calculation applies only to the supplied five-item sample and evidence status.

3. Which evidence request is appropriately specific?

**C. Provide source records for the two removal times and the owner review.**

The request directly addresses the missing closure evidence without inventing historical facts.

4. Why should the finding remain open?

**D. The agreed evidence and review conditions are not met.**

Closure follows the supplied criteria, not personal approval or unsupported accusations.

# 06 Conversation answers

## Governance, Risk, and Compliance

### E Dialogue gaps

Pages 55-56

**1. control design.** Turn 2. Control design concerns the planned rule and process, which policy approval supports without proving operation.

**2. operating effectiveness.** Turn 4. Operating effectiveness concerns actual performance; the incomplete records do not establish it for every sampled case.

**3. sample.** Turn 6. The sample is the five examined cases, so the percentage must be tied to those records and their evidence status.

**4. evidence gap.** Turn 8. The evidence gap is the absence of timestamps needed to determine timeliness, not proof of a late action.

**5. closure criteria.** Turn 10. The closure criteria explicitly require all five cases to be evidenced and owner review recorded.

**6. remediation plan.** Turn 12. The remediation plan can record completed policy work and the remaining evidence and review tasks without falsely closing the finding.

**7. audit trail.** Turn 14. The audit trail records what the evidence shows and how later conclusions are reached without overwriting the uncertainty.

**8. attestation.** Turn 16. An attestation is a formal statement, but it does not replace the source evidence expressly required by these closure criteria.

**9. sampling limitation.** Turn 18. The sampling limitation prevents the five reviewed cases from being presented as proof about every leaver in the organization.

**10. control owner.** Turn 20. The control owner is responsible for gathering the remaining support and completing the required review in this case.

### F Transfer conversation

Page 57

#### 1. timestamp

Auditor: "For the fourth case, we still need the removal timestamp."

The missing removal timestamp is the source evidence needed to compare the action with the deadline.

#### 2. timeliness

Owner: "Without it, I cannot verify that case's timeliness."

Timeliness is unresolved; the missing record does not prove either timely or late removal.

#### 3. review

Auditor: "We also need the recorded owner review."

The local closure criteria separately require an owner review that has not been completed.

#### 4. closure

Owner: "Keep the finding open until the evidence and review meet our conditions for closure."

Closure depends on both outstanding requirements, not merely the existence of the approved policy.

# 07 Briefing and language checks

## Security Awareness and Phishing

### A Briefing checks / page 58

1. What did Ben report doing?

**D. Clicking the link without entering credentials, opening an attachment, or approving a prompt**

The briefing gives a link click and explicitly excludes the other reported actions.

2. How long after the click did Ben report it?

**C. Four minutes**

The time from 09:32 to 09:36 UTC is four minutes.

3. What is the message status?

**C. Not yet classified**

The briefing leaves both message classification and compromise unestablished.

### D Language checks / page 63

1. Which opening is most useful?

**B. Thank you for reporting. What actions did you take, and when?**

The useful opening encourages disclosure and gathers facts without blame or secret collection.

2. Which status accurately reflects the facts?

**B. A suspicious-message report is under assessment; compromise is not established.**

Neither message classification nor compromise has been established in the supplied case.

3. What should Ben use to submit the original?

**A. The approved reporting tool**

The briefing specifies the approved reporting tool and says to avoid further interaction.

4. Which confirmation route avoids trusting the suspicious message?

**D. A previously verified Payroll contact channel**

An independent known channel does not rely on contact details supplied by the suspect message.

# 07 Conversation answers

## Security Awareness and Phishing

### E Dialogue gaps

Pages 64-65

**1. reporting promptly.** Turn 2. Thanking the employee for reporting promptly encourages factual disclosure without blame or promises about employment outcomes.

**2. display name.** Turn 4. The display name is the visible sender label, which does not by itself establish that the message is genuine.

**3. interaction history.** Turn 6. The interaction history distinguishes the click from later actions such as entering data, opening files, or approving prompts.

**4. credential.** Turn 8. A credential supports authentication and should not be disclosed during this factual intake conversation.

**5. compromise.** Turn 10. Compromise is not confirmed, but the absence of reported credential entry alone does not prove that no risk exists.

**6. reporting tool.** Turn 12. The reporting tool is the stated route for submitting the original message without spreading it through an ordinary distribution list.

**7. out-of-band verification.** Turn 14. Out-of-band verification uses a separate trusted route rather than contact details supplied by the suspicious communication.

**8. reporting delay.** Turn 16. The reporting delay is four minutes between the supplied click and report times, not a measure of confirmed harm.

**9. intake.** Turn 18. Intake gathers the relevant facts needed for assessment; omitting the click would distort the response team's understanding.

**10. Message classification.** Turn 20. Message classification remains pending until assessment determines the appropriate category; a familiar label does not settle it.

### F Transfer conversation

Page 66

#### 1. seven

Responder: "The reporting interval was seven minutes."

The interval from 14:10 to 14:17 UTC is seven minutes.

#### 2. credential

Employee: "I report no credential entry."

The supplied fact concerns credential entry rather than every possible interaction or risk.

#### 3. pending

Responder: "Message classification is pending."

The briefing explicitly leaves message classification unresolved at this stage.

#### 4. tool

Employee: "I will use the approved reporting tool."

The local process specifies the approved tool as the reporting route.

# 08 Briefing and language checks

## Executive Risk Briefings

### A Briefing checks / page 67

1. How far did the test exceed the recovery-time objective?

**D. Two hours**

Six hours of observed recovery minus the four-hour objective equals two hours.

2. What does the 800-record illustration mean?

**A. Deferred processing during four hours at the assumed rate**

Four hours multiplied by two hundred records per hour gives deferred processing, not proven loss.

3. What decision is requested?

**B. \$30,000 for recovery automation and repeat testing**

The briefing identifies proposal A and its defined funding purpose.

### D Language checks / page 72

1. Which opening is most decision-ready?

**A. A six-hour recovery test missed the four-hour objective; I request \$30,000 to automate and retest.**

The strongest opening connects evidence, target, action, and amount without inventing an incident.

2. Which statement about data loss is supported?

**C. The supplied test does not establish data loss.**

Recovery duration and data-loss evidence are distinct, and loss is not established here.

3. Why does A rank ahead under the stated priority?

**C. It directly addresses the evidenced payroll recovery shortfall.**

The agreed priority is the measured recovery gap, not price or blanket dismissal of alternatives.

4. What should follow the proposed automation?

**C. Repeat the agreed recovery test and assess evidence against the objective.**

A proposed capability improvement needs verification against the defined recovery objective.

# 08 Conversation answers

## Executive Risk Briefings

### E Dialogue gaps

Pages 73-74

**1. recovery test.** Turn 2. The recovery test supplies the measured six-hour restoration result, distinct from a live incident or a forecast.

**2. recovery-time objective.** Turn 4. The recovery-time objective is the restoration-time target and does not itself measure data loss.

**3. service interruption.** Turn 6. The service interruption is a conditional disruption used to explain the operational consequence, not an event currently occurring.

**4. deferred processing.** Turn 8. Deferred processing means delayed work under the supplied rate assumption, not proven permanent loss or lost revenue.

**5. funding envelope.** Turn 10. The funding envelope is the defined thirty-thousand-dollar request for the stated automation and repeat-testing scope.

**6. risk treatment.** Turn 12. The proposed risk treatment targets the demonstrated recovery shortfall, which the dashboard alternative does not directly address.

**7. success measure.** Turn 14. The success measure is recovery performance against the existing four-hour objective in the agreed repeat test.

**8. Residual exposure.** Turn 16. Residual exposure is the risk remaining outside or after this specific improvement, so the proposal is not a complete risk-elimination claim.

**9. assurance evidence.** Turn 18. Assurance evidence supports the claim that the improved recovery capability actually works after the proposed changes.

**10. decision request.** Turn 20. The decision request asks the authorized sponsor to approve or decline the defined proposal rather than reporting approval as already granted.

### F Transfer conversation

Page 75

#### 1. two

Security: "The test exceeded the objective by two hours."

Five hours minus the three-hour objective equals a two-hour excess.

#### 2. 100

Sponsor: "The illustration uses 100 records per hour."

The briefing supplies an assumed processing rate of one hundred records per hour.

#### 3. 300

Security: "Three hours would defer 300 records."

Three hours multiplied by one hundred scheduled records per hour equals three hundred.

#### 4. unestablished

Sponsor: "Data loss remains unestablished."

The briefing supplies no evidence establishing data loss from the recovery test.

# 09 Conversation answers

## Deleting the post does not revoke the credential

### E Extended conversation

Pages 76-77

- 1. revocation.** Turn 2. Revocation disables the credential itself; deleting a visible copy does not prevent someone who already obtained it from using it.
- 2. credential identifier.** Turn 4. The credential identifier lets responders locate the relevant record without reproducing the authentication secret in another channel.
- 3. secret store.** Turn 8. The secret store is the controlled mechanism for holding and delivering sensitive credentials; a general configuration ticket would create another exposed copy.
- 4. rotation.** Turn 12. Rotation replaces a credential and moves authorized consumers to the replacement; it does not by itself determine whether the exposed credential was misused.
- 5. blast radius.** Turn 14. Blast radius is the scope of affected services or access; discovering another dependent job changes the operational impact assessment.
- 6. audit log.** Turn 18. The audit log provides recorded activity for the available period; missing coverage prevents an unrestricted claim that no misuse occurred.

### F Transfer exchange

Page 78

#### 1. revocation

Engineer: The successful job confirms the new token works, not the old token's revocation.

A successful replacement connection does not demonstrate that the exposed credential can no longer authenticate.

#### 2. result

Lead: Verify rejection through the authorized process and record the result.

The response record needs the actual verification outcome rather than the intended action alone.

#### 3. value

Engineer: The ticket will refer to the controlled record, not include the secret value.

Including the replacement value in a general ticket would create another unnecessary copy of the secret.

#### 4. operation

Lead: Keep the investigation separate from restored service operation.

A running service does not establish whether the exposed credential was misused earlier.

---

Background reading: [OWASP: Secrets Management](#). The conversation is an original fictional teaching case.

# 10 Conversation answers

## A linked service is not automatically in the test scope

### E Extended conversation

Pages 79-80

**1. scope.** Turn 2. Scope defines the approved systems and boundaries; a link from an approved staging service does not add the supplier system to the assessment.

**2. rules of engagement.** Turn 4. Rules of engagement document the permitted assessment activities, boundaries, timing, and handling conditions; they are more specific than a general request to test the application.

**3. test window.** Turn 8. The test window is the authorized time interval in the specified time zone; a calendar conversion does not change the agreed start or end.

**4. stop condition.** Turn 12. A stop condition requires pausing specified activity when a defined event occurs; unexpected real customer information triggers the handling and escalation process in this case.

**5. point of contact.** Turn 16. The point of contact is the designated person for coordination during the assessment; an available, agreed route is necessary for reporting disruption and obtaining instructions.

**6. authorization.** Turn 18. Authorization is permission from the appropriate authority for the specific activity; a stakeholder request or technical reachability does not supply it.

### F Transfer exchange

Page 81

#### 1. environment

Owner: Approval is limited to the named staging environment.

The authorized target is staging; the permitted time does not add production systems.

#### 2. window

Consultant: I will work only within the stated UTC window.

The approved interval limits when the specified assessment activities may occur.

#### 3. methods

Owner: Keep the activity within the listed methods.

Stress testing is expressly excluded and cannot be added merely because the target and time are approved.

#### 4. authorization

Consultant: Any expansion needs separate authorization.

Changes to targets, time, or activities require the appropriate permission before the expanded work begins.

10

Background reading: [NIST: Technical Guide to Information Security Testing and Assessment](#). The conversation is an original fictional teaching case.

# 11 Conversation answers

## The supplier has a report, but what does it cover?

### E Extended conversation

Pages 82-83

**1. reporting period.** Turn 2. The reporting period specifies when the described controls were examined; a January-to-June report does not automatically establish their operation in later months.

**2. system boundary.** Turn 4. The system boundary identifies the services and components described in the report; the supplier name alone does not bring the later add-on into scope.

**3. complementary user entity controls.** Turn 6. Complementary user entity controls are controls expected at the customer that the supplier's control design assumes; receiving the report does not perform those customer responsibilities.

**4. carve-out method.** Turn 8. The carve-out method excludes the subservice organization's controls from this examination; naming the hosting provider does not mean those controls were tested by this report's auditor.

**5. test exception.** Turn 12. A test exception is a deviation identified in the examined control evidence; its nature, context, and implications must be assessed rather than relabeled automatically as a breach.

**6. bridge letter.** Turn 16. A bridge letter provides management's statement about the intervening period; it does not itself extend the independent auditor's examination or add an excluded product.

### F Transfer exchange

Page 84

#### 1. Atlas

Buyer: The described service is Atlas, not every product sold by the supplier.

The supplied system description identifies Atlas and does not include the later product.

#### 2. June

Reviewer: The examination ends in June.

The stated January-to-June period does not itself cover the later months.

#### 3. Nova

Buyer: We still need evidence relevant to Nova.

Nova is part of the purchase but outside the supplied system description and period.

#### 4. approval

Reviewer: Report receipt is not the same as final risk approval.

Receiving the document leaves the scope gaps and required decision unresolved.

11

Background reading: [AICPA: System and Organization Controls](#). The conversation is an original fictional teaching case.

# Find the move you need

Use these as precise language models. Replace details only when you know the actual facts, authority, and agreed conditions.

## 01 Security Triage and Alert Investigation

**Lead with the event:** "The identity log records a successful sign-in at 02:14 UTC."

**Name the plausible explanation:** "The timing overlaps planned maintenance."

**Preserve urgency:** "I am escalating while correlation continues."

Full phrase set: pages 7-8 | Dialogue: pages 10-11

## 02 Incident Response and Containment

**State the current impact:** "Billing jobs are paused on B7."

**Confirm execution:** "Completion was verified at 09:22."

**Assign the decision:** "Restoration requires the response lead and service owner."

Full phrase set: pages 16-17 | Dialogue: pages 19-20

## 03 Vulnerability Management

**Acknowledge the tie:** "Both findings have a base score of 8.8."

**Qualify the threat evidence:** "The bulletin confirms exploitation elsewhere."

**Distinguish availability:** "The patch is available, not yet deployed."

Full phrase set: pages 25-26 | Dialogue: pages 28-29

## 04 Identity, Access, and Least Privilege

**Acknowledge the support need:** "We need to enable the diagnostic work."

**Offer narrower access:** "Read-only access supports that task."

**Keep approval explicit:** "The service owner has not approved it yet."

Full phrase set: pages 34-35 | Dialogue: pages 37-38

# Keep the conversation productive

Use these as precise language models. Replace details only when you know the actual facts, authority, and agreed conditions.

## 05 Threat Modeling and Secure Design

**Start with the request:** "The browser sends a document identifier to the service."

**Acknowledge the existing check:** "The draft checks identity at sign-in."

**Make the abuse case concrete:** "A signed-in user requests another tenant's document."

Full phrase set: pages 43-44 | Dialogue: pages 46-47

## 06 Governance, Risk, and Compliance

**Acknowledge progress:** "The new policy has been approved."

**Give the supported count:** "Three of five records prove timely removal."

**Preserve the closure rule:** "The agreed criteria require evidence for all five cases."

Full phrase set: pages 52-53 | Dialogue: pages 55-56

## 07 Security Awareness and Phishing

**Welcome the report:** "Thank you for reporting it promptly."

**Separate the actions:** "Did you enter credentials, open a file, or approve a sign-in prompt?"

**Stop further interaction:** "Do not interact with the message further."

Full phrase set: pages 61-62 | Dialogue: pages 64-65

## 08 Executive Risk Briefings

**Lead with the gap:** "The test took six hours against a four-hour objective."

**Translate the operation:** "An interruption would delay payroll processing."

**State the request:** "I am requesting \$30,000 for proposal A."

Full phrase set: pages 70-71 | Dialogue: pages 73-74

# Find a term and its context

The page number leads to the definition and a typical word combination. Repeated terms have separate entries when they serve different lesson contexts.

|                                                             |    |
|-------------------------------------------------------------|----|
| <b>abuse case</b> define an abuse case                      | 41 |
| <b>access removal</b> evidence timely access removal        | 51 |
| <b>access review</b> conduct an access review               | 33 |
| <b>accountability</b> preserve individual accountability    | 33 |
| <b>action log</b> maintain the action log                   | 14 |
| <b>affected host</b> identify the affected host             | 15 |
| <b>affected version</b> confirm the affected version        | 23 |
| <b>alert</b> triage an alert                                | 5  |
| <b>anomaly</b> investigate an anomaly                       | 6  |
| <b>asset</b> identify sensitive assets                      | 41 |
| <b>asset criticality</b> assess asset criticality           | 23 |
| <b>assurance evidence</b> collect assurance evidence        | 69 |
| <b>attachment</b> report an unexpected attachment           | 59 |
| <b>attack surface</b> reduce the attack surface             | 23 |
| <b>attestation</b> obtain an owner attestation              | 51 |
| <b>audit trail</b> preserve the audit trail                 | 50 |
| <b>authentication</b> examine authentication records        | 5  |
| <b>authentication check</b> perform an authentication check | 41 |
| <b>authorization</b> confirm authorization                  | 5  |
| <b>authorization check</b> enforce an authorization check   | 41 |
| <b>base score</b> compare base scores                       | 23 |
| <b>baseline</b> compare activity with the baseline          | 6  |
| <b>benign activity</b> confirm benign activity              | 6  |
| <b>break-glass access</b> govern break-glass access         | 33 |

# Find a term and its context

The page number leads to the definition and a typical word combination. Repeated terms have separate entries when they serve different lesson contexts.

|                                                                |    |
|----------------------------------------------------------------|----|
| <b>business consequence</b> connect to a business consequence  | 68 |
| <b>business impact</b> report business impact                  | 15 |
| <b>case record</b> update the case record                      | 6  |
| <b>chain of custody</b> maintain chain of custody              | 14 |
| <b>change approval</b> obtain change approval                  | 24 |
| <b>closure criterion</b> satisfy closure criteria              | 51 |
| <b>closure evidence</b> attach closure evidence                | 24 |
| <b>compensating control</b> evaluate a compensating control    | 24 |
| <b>compromise</b> investigate possible compromise              | 60 |
| <b>confidence level</b> state the confidence level             | 6  |
| <b>containment</b> verify containment actions                  | 14 |
| <b>control design</b> assess control design                    | 50 |
| <b>control frequency</b> specify control frequency             | 51 |
| <b>control objective</b> define the control objective          | 50 |
| <b>control owner</b> identify the control owner                | 50 |
| <b>correlation</b> correlate identity and host logs            | 6  |
| <b>credential</b> protect authentication credentials           | 59 |
| <b>credential harvesting</b> investigate credential harvesting | 59 |
| <b>CVE</b> reference a CVE identifier                          | 23 |
| <b>CVSS</b> interpret a CVSS score                             | 23 |
| <b>data flow</b> trace the data flow                           | 41 |
| <b>data store</b> identify data stores                         | 41 |
| <b>decision authority</b> confirm decision authority           | 15 |
| <b>decision request</b> frame the decision request             | 69 |

# Find a term and its context

The page number leads to the definition and a typical word combination. Repeated terms have separate entries when they serve different lesson contexts.

|                                 |                                   |    |
|---------------------------------|-----------------------------------|----|
| <b>deferred processing</b>      | quantify deferred processing      | 68 |
| <b>denial of service</b>        | assess denial-of-service risk     | 42 |
| <b>deprovisioning</b>           | verify deprovisioning             | 33 |
| <b>display name</b>             | inspect the display name          | 59 |
| <b>document identifier</b>      | validate the document identifier  | 42 |
| <b>elevation of privilege</b>   | prevent elevation of privilege    | 42 |
| <b>entitlement</b>              | review entitlements               | 32 |
| <b>entry point</b>              | review entry points               | 41 |
| <b>eradication</b>              | verify eradication                | 14 |
| <b>event</b>                    | correlate events                  | 5  |
| <b>evidence gap</b>             | resolve an evidence gap           | 51 |
| <b>evidence preservation</b>    | coordinate evidence preservation  | 14 |
| <b>evidence request</b>         | issue an evidence request         | 50 |
| <b>exception</b>                | investigate an exception          | 51 |
| <b>exception expiry</b>         | track exception expiry            | 24 |
| <b>exfiltration</b>             | investigate possible exfiltration | 15 |
| <b>expiry</b>                   | record access expiry              | 33 |
| <b>exploit</b>                  | assess exploit availability       | 23 |
| <b>exploitation in the wild</b> | confirm exploitation in the wild  | 23 |
| <b>external entity</b>          | identify external entities        | 41 |
| <b>false finding</b>            | investigate a false finding       | 24 |
| <b>false positive</b>           | validate a false positive         | 6  |
| <b>federation</b>               | configure identity federation     | 32 |
| <b>finding</b>                  | track an audit finding            | 51 |

# Find a term and its context

The page number leads to the definition and a typical word combination. Repeated terms have separate entries when they serve different lesson contexts.

|                                                                             |    |
|-----------------------------------------------------------------------------|----|
| <b>funding envelope</b> specify the funding envelope                        | 69 |
| <b>governance</b> strengthen security governance                            | 50 |
| <b>handover</b> complete the response handover                              | 15 |
| <b>hypothesis</b> test the maintenance hypothesis                           | 6  |
| <b>identity and access management</b> review identity and access management | 32 |
| <b>impact estimate</b> state the impact estimate                            | 68 |
| <b>impersonation</b> assess possible impersonation                          | 59 |
| <b>implementation dependency</b> identify implementation dependencies       | 69 |
| <b>incident</b> classify an incident                                        | 5  |
| <b>incident response</b> coordinate incident response                       | 14 |
| <b>incident scope</b> establish incident scope                              | 15 |
| <b>independent review</b> conduct an independent review                     | 51 |
| <b>indicator</b> assess an indicator                                        | 6  |
| <b>information disclosure</b> prevent information disclosure                | 42 |
| <b>intake</b> complete security intake                                      | 60 |
| <b>interaction history</b> record interaction history                       | 60 |
| <b>internet-facing</b> inventory internet-facing assets                     | 23 |
| <b>investment case</b> present an investment case                           | 69 |
| <b>just-in-time access</b> request just-in-time access                      | 33 |
| <b>KEV catalog</b> check the KEV catalog                                    | 23 |
| <b>known contact channel</b> use a known contact channel                    | 60 |
| <b>lateral movement</b> investigate possible lateral movement               | 15 |
| <b>least privilege</b> apply least privilege                                | 32 |
| <b>leaver process</b> verify the leaver process                             | 51 |

# Find a term and its context

The page number leads to the definition and a typical word combination. Repeated terms have separate entries when they serve different lesson contexts.

|                                                                      |    |
|----------------------------------------------------------------------|----|
| <b>likelihood</b> qualify the likelihood estimate                    | 68 |
| <b>link destination</b> assess the link destination                  | 59 |
| <b>log source</b> identify the log source                            | 6  |
| <b>maintenance window</b> confirm the maintenance window             | 5  |
| <b>message classification</b> confirm message classification         | 60 |
| <b>message header</b> preserve message headers                       | 59 |
| <b>MFA prompt</b> report an unexpected MFA prompt                    | 60 |
| <b>mitigation</b> verify a mitigation                                | 24 |
| <b>multifactor authentication</b> require multifactor authentication | 32 |
| <b>named account</b> provision a named account                       | 32 |
| <b>network isolation</b> confirm network isolation                   | 14 |
| <b>object-level authorization</b> verify object-level authorization  | 42 |
| <b>operating effectiveness</b> test operating effectiveness          | 50 |
| <b>out-of-band verification</b> use out-of-band verification         | 60 |
| <b>patch</b> validate a patch                                        | 24 |
| <b>persistence</b> assess persistence                                | 15 |
| <b>phishing</b> report suspected phishing                            | 59 |
| <b>playbook</b> follow the approved playbook                         | 14 |
| <b>policy</b> approve an access policy                               | 50 |
| <b>population</b> establish the population                           | 50 |
| <b>post-incident review</b> schedule a post-incident review          | 15 |
| <b>pretext</b> identify the pretext                                  | 59 |
| <b>privileged access</b> control privileged access                   | 32 |
| <b>privileged account</b> review privileged-account activity         | 5  |

# Find a term and its context

The page number leads to the definition and a typical word combination. Repeated terms have separate entries when they serve different lesson contexts.

|                                                                          |    |
|--------------------------------------------------------------------------|----|
| <b>procedure</b> maintain the removal procedure                          | 50 |
| <b>process</b> model the service process                                 | 41 |
| <b>processing backlog</b> estimate the processing backlog                | 68 |
| <b>provisioning</b> complete access provisioning                         | 32 |
| <b>quarantine</b> verify quarantine status                               | 60 |
| <b>reachability</b> verify reachability                                  | 23 |
| <b>read-only access</b> grant read-only access                           | 32 |
| <b>recovery</b> authorize recovery                                       | 14 |
| <b>recovery test</b> run a recovery test                                 | 68 |
| <b>recovery-point objective</b> distinguish the recovery-point objective | 68 |
| <b>recovery-time objective</b> test the recovery-time objective          | 68 |
| <b>regression test</b> run regression tests                              | 24 |
| <b>remediation</b> prioritize remediation                                | 24 |
| <b>remediation plan</b> review the remediation plan                      | 51 |
| <b>remediation window</b> agree a remediation window                     | 24 |
| <b>reply-to address</b> compare the reply-to address                     | 59 |
| <b>reporter</b> acknowledge the reporter                                 | 60 |
| <b>reporting delay</b> measure reporting delay                           | 60 |
| <b>reporting tool</b> use the reporting tool                             | 60 |
| <b>rescan</b> perform a rescan                                           | 24 |
| <b>residual exposure</b> disclose residual exposure                      | 69 |
| <b>residual risk</b> assess residual risk                                | 51 |
| <b>resilience</b> improve operational resilience                         | 68 |
| <b>response lead</b> brief the response lead                             | 14 |

# Find a term and its context

The page number leads to the definition and a typical word combination. Repeated terms have separate entries when they serve different lesson contexts.

|                                                                |    |
|----------------------------------------------------------------|----|
| <b>restoration criterion</b> confirm restoration criteria      | 15 |
| <b>retention period</b> apply the retention period             | 51 |
| <b>review trigger</b> define a review trigger                  | 69 |
| <b>risk acceptance</b> document risk acceptance                | 24 |
| <b>risk appetite</b> clarify risk appetite                     | 69 |
| <b>risk exposure</b> explain risk exposure                     | 68 |
| <b>risk scenario</b> describe a risk scenario                  | 68 |
| <b>risk treatment</b> select risk treatment                    | 69 |
| <b>role-based access</b> configure role-based access           | 32 |
| <b>root cause</b> establish the root cause                     | 15 |
| <b>sample</b> define the audit sample                          | 50 |
| <b>sampling limitation</b> disclose sampling limitations       | 50 |
| <b>sanitized logs</b> share sanitized logs                     | 33 |
| <b>security requirement</b> specify a security requirement     | 41 |
| <b>sender address</b> verify the sender address                | 59 |
| <b>separation of duties</b> maintain separation of duties      | 33 |
| <b>server-side enforcement</b> require server-side enforcement | 42 |
| <b>service account</b> manage service-account permissions      | 33 |
| <b>service interruption</b> assess service interruption        | 69 |
| <b>service owner</b> involve the service owner                 | 14 |
| <b>session record</b> review session records                   | 33 |
| <b>shared account</b> review shared-account risk               | 32 |
| <b>single sign-on</b> support single sign-on                   | 32 |
| <b>social engineering</b> recognize social-engineering tactics | 59 |

# Find a term and its context

The page number leads to the definition and a typical word combination. Repeated terms have separate entries when they serve different lesson contexts.

|                            |                                      |    |
|----------------------------|--------------------------------------|----|
| <b>source address</b>      | investigate a source address         | 5  |
| <b>spoofing</b>            | assess spoofing threats              | 42 |
| <b>standing privilege</b>  | reduce standing privilege            | 33 |
| <b>status update</b>       | issue a status update                | 15 |
| <b>STRIDE</b>              | apply STRIDE categories              | 42 |
| <b>success measure</b>     | agree success measures               | 69 |
| <b>successful sign-in</b>  | verify a successful sign-in          | 5  |
| <b>tampering</b>           | prevent data tampering               | 42 |
| <b>telemetry</b>           | review available telemetry           | 6  |
| <b>tenant</b>              | isolate tenant data                  | 42 |
| <b>tenant isolation</b>    | test tenant isolation                | 42 |
| <b>threat model</b>        | review the threat model              | 41 |
| <b>time-bound access</b>   | approve time-bound access            | 33 |
| <b>timestamp</b>           | preserve the timestamp               | 5  |
| <b>tolerance threshold</b> | specify a tolerance threshold        | 69 |
| <b>triage</b>              | perform security triage              | 5  |
| <b>trust boundary</b>      | identify a trust boundary            | 41 |
| <b>uncertainty range</b>   | report an uncertainty range          | 68 |
| <b>untrusted input</b>     | handle untrusted input               | 42 |
| <b>urgency cue</b>         | identify an urgency cue              | 60 |
| <b>UTC</b>                 | report times in UTC                  | 5  |
| <b>visibility gap</b>      | disclose a visibility gap            | 6  |
| <b>volatile data</b>       | preserve volatile data appropriately | 14 |
| <b>vulnerability</b>       | assess a vulnerability               | 23 |

# Original cases. Clear boundaries.

These are original fictional teaching conversations, not transcripts of real workers. Names, figures, organizations, and incidents are invented. Sources support terminology and communication aims, not the fictional results or an endorsement of this book.

## **[1] NIST. SP 800-61 Revision 3: Incident Response Recommendations and Considerations, April 2025.**

[Open the original source](#)

Background for incident-response vocabulary and the distinction between detection, response, and recovery. The case actions and authority arrangements are fictional. Checked 30 September 2026.

## **[2] CISA. Known Exploited Vulnerabilities Catalog.**

[Open the original source](#)

Background for using observed exploitation as one prioritization input. No invented vulnerability in this book is represented as an actual catalog entry. Checked 30 September 2026.

## **[3] OWASP. Threat Modeling Cheat Sheet.**

[Open the original source](#)

Background for system modeling, data flows, trust boundaries, and testable mitigations. The application and review findings are original fictional cases. Checked 30 September 2026.

## **[4] NIST. SP 800-53 Revision 5: Security and Privacy Controls for Information Systems and Organizations.**

[Open the original source](#)

Background for access, accountability, assurance, and control vocabulary. The local policies and closure criteria in the exercises are not universal compliance rules. Checked 30 September 2026.

---

## **Phil Stilwell**

© 2026 Phil Stilwell. All rights reserved.

No part of this publication may be reproduced, stored in a retrieval system, or transmitted in any form or by any means without prior written permission from the author, except as permitted by law.

Original fictional English practice, not a security certification, incident-response playbook, legal opinion, or authorization to test systems. Follow the responsible team, approved procedures, evidence-handling rules, and applicable requirements. All organizations, incidents, figures, priorities, and control criteria in the cases are invented.

English Ladder | English for Work | 2026 edition. The B2-C1 range is an editorial study recommendation, not a proficiency certification.

[Open the matching English Ladder course](#)